AUTOMATED SECURITY CLASSIFICATION

Kassidy Patrick Clark

Capgemini

CONSULTING.TECHNOLOGY.OUTSOURCING

Author:

Name:	:	Kassidy Patrick Clark
E-mail	:	kpclark@few.vu.nl, kas.clark@capgemini.com
Telephone	:	+31 (0) 642157047

Organisation

Name	:	Capgemini Netherlands B.V.
Department	:	(F55) Infrastructure & Architecture
Telephone	:	+31 (0) 306890000
Address	:	Papendorpseweg 100, 3500GN Utrecht
Website	:	http://www.nl.capgemini.com

University

Name	:	Vrije Universiteit
Department	:	Exact Sciences
Telephone	:	+31 (0) 205987500
Address	:	De Boelelaan 1083, 1081HV Amsterdam
Website	:	http://www.few.vu.nl

Organisational Supervisor(s)

Name	:	Drs. Marco Plas
E-mail	:	marco.plas@capgemini.com
Telephone	:	+31 (0) 306890000
Name	:	Drs. Alina Stan
E-mail	:	alina.stan@capgemini.com
Telephone	:	+31 (0) 306895111

University Supervisor(s)

Name	:	Thomas B. Quillinan, Ph.D.
E-mail	:	tb.quillinan@few.vu.nl
Phone number	:	+31 (0) 205987634
Name	:	Prof. dr. Frances Brazier
E-mail	:	frances@cs.vu.nl
Phone number	:	+31 (0) 205987737

Copyright © 2008 Capgemini – All rights reserved

AUTOMATED SECURITY CLASSIFICATION

Kassidy Patrick Clark

A dissertation submitted to the Faculty of Exact Sciences,

Vrije Universiteit, Amsterdam

in partial fulfilment of the requirements for the degree of

Master of Science

Fall 2008

“Classification is the pivot on which the whole subsequent security system turns...”

- Arvin Quist

TABLE OF CONTENTS

1. INTRODUCTION 1

1.1. MOTIVATION 1
1.2. RESEARCH APPROACH AND SCOPE 3
1.3. RESEARCH GOALS 4
1.4. RESEARCH STRUCTURE 4
1.5. ORGANISATION 5

2. BACKGROUND 6

2.1. DE-PERIMETERISATION 6
2.2. JERICHO FORUM 6
2.3. SECURITY CLASSIFICATION 7
2.4. NATURAL LANGUAGE PROCESSING 7
2.5. DATA CLASSIFICATION FOR INFORMATION RETRIEVAL 9
2.6. INFORMATION LIFECYCLE MANAGEMENT 12
2.7. CONCLUSION 14

3. SECURITY CLASSIFICATION IN PRACTICE 15

3.1. MOTIVATIONS AND TRADE-OFFS OF DATA SECURITY 15
3.2. THE ROLE OF CLASSIFICATION 16
3.3. CLASSIFICATION IN PRACTICE 17
3.4. CONCLUSION 20

4. CLASSIFICATION REQUIREMENTS AND TECHNOLOGIES 21

4.1. SECURITY CLASSIFICATION DECISION FACTORS 21
4.2. PARSING TECHNOLOGY 29
4.3. AUTOMATED TEXT CLASSIFICATION METHODS 30
4.4. CONCLUSION 40

5. MODEL FOR AUTOMATED SECURITY CLASSIFICATION 41

5.1. OVERVIEW OF THE MODEL 41
5.2. COMPONENTS OF THE MODEL 42
5.3. APPLICATIONS OF THE MODEL 46
5.4. CONCLUSION 51

6. CONCLUSION 52

6.1. SUMMARY OF MOTIVATION 52
6.2. SUMMARY OF RESEARCH 52
6.3. OPEN ISSUES 54
6.4. FUTURE WORK 54

REFERENCES 56
APPENDIX A. INTERVIEWS 63
APPENDIX B. NIST SECURITY CATEGORISATIONS 65
APPENDIX C. CLASSIFICATION FORMULAS 67
APPENDIX D. OVERVIEW OF CURRENT PRODUCTS 69

Copyright © 2008 Capgemini – All rights reserved

LIST OF FIGURES

FIGURE 1-1 INITIAL MODEL OF ASC. 3
FIGURE 2-1 LIFECYCLE BASED ON VALUE OVER TIME [38] 13
FIGURE 3-1 FORRESTER RESEARCH 2008 SURVEY [51]. 18
FIGURE 3-2 TRAFFIC LIGHT PROTOCOL AS USED BY ELI LILLY. 19
FIGURE 4-1 DECISION TREE FOR SECURITY CLASSIFICATION [54]. 22
FIGURE 4-2 NIST SECURITY CATEGORIES. 26
FIGURE 4-3 EXAMPLE OF LSI CLASSIFICATION [19]. 34
FIGURE 4-4 EXAMPLE RULE-BASED CLASSIFIER AND THE DERIVED DECISION TREE [20]. 35
FIGURE 4-5 BAYESIAN CLASSIFIER. 35
FIGURE 4-6 SVM CLASSIFIER [20]. 37
FIGURE 4-7 EXAMPLE HEADERS OF E-MAIL TAGGED BY SPAMASSASSIN. 38
FIGURE 5-1 GENERIC MODEL OF AUTOMATED SECURITY CLASSIFICATION (ASC). 41
FIGURE 5-2 EXAMPLE OF DOCUMENT TAXONOMY. 46

Copyright © 2008 Capgemini – All rights reserved

LIST OF TABLES

TABLE 2-1 CLASSIFICATION DECISION MATRIX [19] 9
TABLE 3-1 COMPUTERWORLD 2006 SURVEY [49] 18
TABLE 4-1 GOVERNMENT SECURITY CLASSIFICATIONS WITH RATIONALE [52] 21
TABLE 4-2 POTENTIAL IMPACT DEFINITIONS FOR EACH SECURITY OBJECTIVE [57]. 25
TABLE 4-3 EXAMPLES OF RESTRICTED DATA [62]. 27
TABLE 4-4 SENSITIVITY TO INFORMATION MAPPING [66]. 27
TABLE 4-5 PERFORMANCE MEASURES OF CLASSIFIERS [70]. 39
TABLE 5-1 FORMAT OF METADATA REPOSITORY. 44

Copyright © 2008 Capgemini – All rights reserved

1. INTRODUCTION

This dissertation deals with the area of electronic data protection. More specifically, we are concerned with the ability to automate the process of assigning appropriate protection to data, based on the specific sensitivity of an individual piece of electronic data. Determining the appropriate security measures requires accurate classification of the data. Currently, the most common method of classifying data for security purposes is to perform this classification manually. There are several areas for improvement to this approach regarding speed and consistency. The premise of this thesis is the possibility of automating this process by applying new technologies from the fields of information retrieval and artificial intelligence to the field of data security.

1.1. MOTIVATION

A trend in electronic security appears to be re-emerging that places the focus of protection on the data itself, rather than solely on the infrastructure. This new paradigm is sometimes referred to as "data-centric" as the focus is to protect the information directly, independently of the underlying infrastructure. In contrast, the current security model is thus referred to as "infrastructure-centric" as the predominant focus is on protecting information by securing the underlying infrastructure that stores, transmits, or processes the data. [1]

This need is motivated, in part, by the obligation to comply with government regulation regarding protection and privacy of personal information, such as medical or credit card information. In addition, confidentiality of sensitive information in a certain context is sometimes necessary for a corporation to maintain its reputation and competitive advantage. For instance, a highly publicised story of sensitive customer information being lost might deter future customers from taking a similar risk. Potentially even more damaging to a corporation would be the loss of its competitive advantage, such as would occur if a competitor were to gain access to the designs of the latest product, before it is brought to the market. An overview, indicating the frequency and scope of the problem of data loss can be found in [2] and [3].

The problem of securing data becomes more urgent when we take into consideration that an estimated 80% of data is unstructured, such as text documents or e-mails [4]. This data is especially difficult to secure as the exact identity or location of the data is not always known. Furthermore, market analysts estimate that this data is doubling every three to six months [5]. This occurs not only when new documents are created, but also when documents are copied into different versions or different locations, such as when copies of emails are stored on different servers.

Many security measures already exist, such as encryption technologies, and are incorporated in products that can protect the confidentiality of our enterprise data on a per document basis. Thus, the problem is not *how* we can protect the data, but rather knowing *what* data needs to be protected. Not all data is of equal value, therefore, not all data should be handled and protected in the same manner. For instance, a company white paper has no

Copyright © 2008 Capgemini – All rights reserved

need of being kept confidential, whereas the details of an upcoming product release might warrant such protection.

Data protection counter measures should therefore be deployed *appropriately* and *specifically* to each piece of data, based on the sensitivity of the individual data. In order for the assignment of security measures to be precise, we should deal with the data at the finest possible level of granularity. Therefore, determining the appropriate security measures seems to first require accurate classification of the data, by identifying and labelling sensitive data.

On one side, we have growing corpus of unstructured data and, on the other side, we have a host of security mechanisms, such as encryption, Digital Rights Management (DRM), access controls, and so on. These security mechanisms should be mapped to the data in a way that is both specific and appropriate. Therefore, what seems to be required is a way of determining the function that performs this mapping. In order to achieve this, we should know the data that is sensitive and must be kept confidential. This is attained by classifying the data based on its sensitivity and the damage that would be caused by an unauthorised disclosure. The importance of this initial classification should not be underestimated:

> *"The initial classification determination, establishing what should not be disclosed to adversaries and the level of protection required, is probably the most important single factor in the security of all classified projects and programs. None of the expensive personnel-clearance and information-control provisions… come into effect until information has been classified; classification is the pivot on which the whole subsequent security system turns…" [6].*

Currently, the most common method of classifying data for security purposes is to perform this classification manually. For instance, the author of a document can assign a classification rating, or fill in some other metadata at the time of creation. However, this manual process can suffer from several shortcomings regarding speed and consistency. The speed of a manual classification depends on the time needed to read the text, understand the security implications and then classify the document accordingly. The consistency of a manual classification depends on many other factors, such as the training and attention of the classifier. Even under ideal circumstances, proper classification requires time and effort to thoroughly read each document and understand the security issues at hand. This problem becomes much larger when we consider the enormous backlog of documents and email that have already been created and would also require classification.

This is where the science of automated data classification can play a crucial role. If it is possible to fully, or even partially, automate the process of accurate classification of data, based on the sensitivity of its contents, then an important piece of the chain will be complete. This might allow security measures to be applied to the large amounts of enterprise data on a more specific and appropriate scale.

Substantial research has already been carried out on the ability of automating the process of data classification. This research has mainly focused on applying artificial intelligence techniques to automate the decision making process according to statistical analysis of the data. These techniques range from simple statistical word usage analysis to complex semantic analysis. Each technique has its own advantages regarding the trade-off between accuracy and performance.

Copyright © 2008 Capgemini – All rights reserved

The objective of this thesis is to gain understanding of the possibilities of these automated data classification technologies in this new context of data protection. This will be facilitated by designing a generic model of automated security classification. This model will allow us to identify both the capabilities of state of the art technology at achieving this model, as well as the challenges that must still be addressed.

1.2. Research Approach and Scope

This section will describe how we will approach this problem by first designing an initial model to understand the elements and components that are required to accomplish our goal, and then researching the technologies required to realise each of these elements. This model will be further refined as our understanding of the needs and realities of the situation improve. We will also state the goals of this thesis and the steps that must be taken to reach them.

This research will begin with an initial model of Automated Security Classification, as depicted in Figure 1-1.

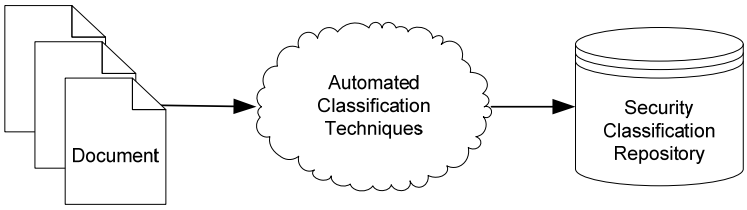

Figure 1-1 Initial model of ASC.

This model identifies three main components:

- **Document** – This represents the input of unstructured text documents, in the form of e-mail, text documents, and so on.
- **Automated Classification Techniques** – This represents the techniques that have been developed and researched for automated categorisation for information retrieval.
- **Security Classification Repository** – This represents the final output of clearly defined security levels for each separate document, such as Secret, Public, and so on. This will then be the input of any further applications, such as work flow management or rights management.

The problem will be addressed initially by defining the requirements of the output of the model. The next step will be to list and evaluate current classification technologies in this context to understand their capabilities and limits. As a result of these activities, the model will be further refined and developed, that will in turn guide further research.

The initial model reveals two main areas of research. First, there is the matter of text classification. Second, there is the matter of the security decision. The initial scope of this project included both of these aspects. However, following the recommendation of multiple advisors in both fields, the scope has been narrowed to the matter of text classification. This dissertation will, thus, focus on the technologies that can be used to automatically classify text, in preparation for a security classification. However, the details of the subsequent

Copyright © 2008 Capgemini – All rights reserved

security classification and the security policies involved will not be covered in this dissertation.

Different applications of this model will have different requirements regarding the factors that are taken into consideration for the security decision (security policies) and the particular security classification scheme followed. For this reason, this dissertation will focus mainly on the part of the model that should remain the same, regardless of the application, namely the techniques used to build the metadata repository. We will address the security decision part of the model only insofar as it defines the general requirements of the metadata repository. This will be kept as generic as possible in order to provide better integration with implementation specific security policies.

The majority of this dissertation will be developed through the consultation of various literature on the subjects of security classification and text classification. This will be supplemented by interviews with professionals in the various fields involved. These interviews will serve to give an idea of the current situation in the corporate world, as well as to evaluate the usefulness or feasibility of the final model.

1.3. Research Goals

The goal of this research is to determine if the process of building the metadata repository used for security classification can be fully, or even partially automated using techniques developed for other data classification systems, such as statistical or semantic analysis of unstructured text. In terms of the initial model (see Figure 1-1), this will include evaluating automated methods of extracting the relevant metadata from the set of documents and structuring these in the repository.

To reach this goal, several sub-challenges must be addressed:

- determining the relevant metadata that must be stored in the repository;
- determining what relevant information is provided by the documents that must be classified, including their contents and extrinsic metadata, and
- evaluating current techniques for automated categorisation of unstructured text.

The contribution of this thesis is the introduction of the concept of automated security classification, as well as the proposal of a model and several technologies to realise this concept. We intend to show how the power of advanced text classification techniques can be harnessed to improve the speed and accuracy of identifying sensitive documents for security purposes.

1.4. Research Structure

In general, this subject will initially be approached in two ways. First, we will assess the general requirements of the metadata repository. This will involve looking at the factors that are taken into account to reach a security classification decision, independent from the actual classification scheme. Possible factors could be knowledge of the subject matter (sensitive topics), understanding of the relationships to other documents (same author or group), or a more abstract awareness of the risks and consequences of a security breach (security

Copyright © 2008 Capgemini – All rights reserved

intuition). For reasons previously stated, this area of research will be kept as generic as possible, in order to identify the general requirements of the metadata repository.

Secondly, we will study the technologies of automated data classification as are used in the fields of information retrieval in order to understand their true abilities and applications. This will involve researching the different techniques used, such as linguistic and statistical analysis. The different steps of classification will be described, along with the various methods of performing each of these steps. This will also include evaluating the relative advantages and disadvantages of the different methods.

After this initial research, we will look at the most common current situations: no classification, or strictly manual classification. We will try to identify the significant problems with this situation in order to evaluate the success of our proposed solution at solving these issues. Then, we will return to our initial model of automated classification (see Figure 1-1) and further develop the connections between the documents and the metadata repository, using the techniques covered. Finally, we will evaluate the model to identify which of the initial problems have been solved and what challenges still remain. This will involve use cases where the model can be implemented to solve a certain problem.

1.5. ORGANISATION

This dissertation will be organised in the following way. Chapter 2 gives general background information about the context of this research and the concepts that will have major roles in the research. This will include data security trend of de-perimeterisation, security classification, and classification techniques, such as natural language processing and their current uses in other fields.

Chapter 3 describes the current situation facing companies today. This will include an overview of motivations for improved data security, the importance of data classification, and current security classification schemes in use. Chapter 4 provides further detail on the area of security classification, and the current automated text classification technologies.

Chapter 5 presents the proposed model of automated security classification. This will involve discussing each component in detail, as well as thoroughly researching their requirements and possible solutions. Also, several applications of the generic model will be proposed as a way of evaluating the strengths and practicalities of this technology. Chapter 6 concludes this dissertation by summarising our findings and making suggestions for further uses of the proposed model and future areas of research.

Copyright © 2008 Capgemini – All rights reserved

2. BACKGROUND

This chapter will discuss the background information of security classification. This will include an overview of the relevant security trends; the organisations involved; definitions of important concepts, and an overview of relevant technologies.

2.1. DE-PERIMETERISATION

The paradigm shift towards data-centric security is just one piece of a larger trend towards "de-perimeterisation," that calls for a modification of the current security model. The current security model is based on the concept of a safe local network protected from the dangerous outside world through the use of a secured perimeter of firewalls; intrusion detection systems, and so on. This model appears flawed for several reasons. First, a large percentage of security breaches occur inside the safe network. According to the 2007 Computer Crime and Security Survey [7], 64% of business reported attacks originating from inside the corporate network. This indicates that the majority of businesses have experienced internal attacks that completely circumvented the perimeter defences.

Secondly, companies are constantly making holes in their perimeter to allow for business interaction with partners and customers. According to the global head of BT security practice, this is increasingly driven by the growing trends of 1) mobile workers, who require fast, secure access to corporate resources from any location; 2) cheaper and ubiquitous internet connectivity, which is steadily replacing leased private lines, and 3) interaction with third parties, such as customers and partners [8]. The growing trend of web-based interaction adds to the breaking down of strict perimeter security rules. More businesses are offering direct access to their network via web-services to their customers or other companies. This is expected to increase as the changing business model demands more interaction with outside entities, driven by outsourcing, joint ventures, and closer collaboration with customers [8].

The proposed solution is to "de-perimeterise" the security model. In general terms, this means that we should refocus on the fact that the local network can be as dangerous as the Internet. The security measures should no longer be concentrated on an imaginary perimeter that encompasses the entire enterprise, but should rather be refocused and relocated to protect each individual asset of value.

2.2. JERICHO FORUM

A group arguing for de-perimeterisation is the Jericho Forum, founded by the Open Group. The mission of this group is to develop a new, data-centric model of security called a Jericho Network. This model holds that the focus of security should no longer be solely on the outer perimeter of a company, but should rather be focussed on the actual assets that warrant protection. This model offers a more defence-in-depth approach which includes secured communication channels, secured end points, secured applications and finally individually secured data. Ultimately, each piece of data should be able to protect itself, no matter if in use, in transit or in storage. [9]

Copyright © 2008 Capgemini – All rights reserved

The core beliefs of the Jericho Network model are clarified in The 11 Commandments of Jericho. These embody the ideal principles that the Jericho Forum argue are necessary to achieve a new data protection paradigm better suited to the current digital environment. Specific to our purposes are the following three [9]:

JFC 1 The scope and level of protection should be specific and appropriate to the asset at risk.

JFC 9 Access to data should be controlled by security attributes of the data itself.

JFC 11 By default, data must be appropriately secured when stored, in transit and in use.

2.3. Security Classification

Security classification is the task of assigning an object, such as a document, to a pre-defined level, based on the sensitivity of the contents and the negative impact that would result if confidentiality were breached. The relationship between classification and security can be succinctly stated as:

> *"Classification identifies the information that must be protected against unauthorized disclosure. Security determines how to protect the information after it is classified" [6].*

These security classifications are stored in security, or sensitivity, labels that are a lattice of classification levels, such as *Top Secret, Secret, Classified*, and horizontal categories, such as department or project.

> *"A subject can read an object only if the hierarchical classification in the subject's security level is greater than or equal to the hierarchical classification in the object's security level and the non-hierarchical categories in the subject's security level include all the non-hierarchical categories in the object's security level." [10]*

Security labels are essential to controlling access to sensitive information as they dictate which users have access to that information. Therefore, these labels form the basis for any access decisions following mandatory access control policies, such as those explained in [11]. "Once information is unalterably and accurately marked, comparisons required by the mandatory access control rules can be accurately and consistently made" [10].

A specific security classification scheme is neither pursued by, nor required for, this research. However, we are interested in the fundamental factors that are taken into consideration when a document is assigned a security classification. As our model is meant to be independent of the particular implementation and security classification scheme, we will continue to refer to security classification only in the generic sense.

2.4. Natural Language Processing

Natural Language Processing (NLP) has become a catch-all phrase for the field of computer science that it devoted to "enabling computers to use human languages both as input and as output" [12]. This should lead to the point where computers and humans could not be told apart by the well-known Turing Test, as described in [13]. Much research has been devoted to achieving this goal, but results have all fallen short of expectations. This is mainly due to

Copyright © 2008 Capgemini – All rights reserved

the high complexity and inherent ambiguity of language, both spoken and written. An ironic example of this is given by [12] when quoting an advertisement by McDonnell-Douglas, which confidently touted the future achievements of NLP. The advertisement read:

"At last, a computer that understands you like your mother."

Unfortunately, this sentence reveals the inherent ambiguity of language, as it can be interpreted (by a computer) in three different ways:

1. The computer understands you as well as your mother understands you.
2. The computer understands that you like your mother.
3. The computer understands you as well as it understands your mother.

Rather than being a separate classifier, in and of itself, NLP can be seen as a driving element that reveals itself in some of the classifiers described in this dissertation. Two main approaches to NLP can be identified: 1) symbolic (or linguistic) and 2) stochastic (or statistical). Much research has been devoted to each of these areas, resulting in the development of classifiers that make use of one or the other and sometimes even both [14].

The symbolic approach attempts to use language rules regarding syntax and semantics to parse sentences and establish equivalent information for individual words, such as part of speech and (precise) definition. This requires additional overhead to provide not only this linguistic knowledge, but also all the necessary knowledge to derive context, such as for proper nouns. For instance, the name of the current president is required to know if a certain statement refers to a current president (current events) or a past president (historical events). Practical application of this approach is seen in *lemmatisation* and *part-of-speech (POS)* tagging. Lemmatisation is another term for word-stemming (see Chapter 5), where different inflected forms of words are grouped together, such as *walk, walker, walking*. Part-of-speech (POS) tagging is the process of parsing a sentence to identify and label verbs, and nouns (subjects and objects). This can then be useful for dealing with synonymy and polysemy to establish clear context.

The stochastic approach, in contrast, is less concerned with linguistics and more with pure mathematics. This approach is introduced in [15]. Instead of a knowledge base, this approach requires examples of natural language; the more the better. By using mathematics to reveal statistical patterns in similar texts, a machine will be able to predict the meaning (category or subject) of a new text. According to Professor Koster of Radboud University (see Appendix A), this approach is steadily becoming the more popular approach, at least for the area of large scale text classification.

Most of the classifiers described in this dissertation fall under this statistical approach. Some techniques make use of both approaches, such as lemmatisation before statistical analysis, but, according to Koster, this has little added value to the accuracy of the statistical analysis without prior lemmatisation. This is an opinion shared by [16] who question the added value of linguistic processing, despite the existence of accurate and efficient POS taggers. In fact, in some cases, this linguistic pre-processing might hurt the accuracy of statistical classifiers. That is not to say that all hope is lost for the practicality of the linguistic approach, but rather that more research is required. Some research has shown that NLP pre-

Copyright © 2008 Capgemini – All rights reserved

processing to first identify proper nouns, terminological expressions (lemmatisation) and parts-of-speech can be used in conjunction with a Rocchio classifier to reach accuracy levels on par with Support Vector Machines (SVM) with considerable benefits to performance [17, 18]. Research is still active in this field and future classifiers could make use of both linguistic and statistical approaches.

2.5. Data Classification for Information Retrieval

Data classification (or categorisation) is the task of assigning a piece of data, such as a text document to one (or more) predefined categories. For example, imagine a set of various news articles that needs to be divided into appropriate categories, such as politics or sports. The task of classification is to derive rules that accurately organise these articles into these groups, based, in general, solely on their contents. In other words, we cannot necessarily assume that any additional information is given, such as author or title. In this context, the notion of data refers to documents consisting of unstructured text with optional metadata, such as modification dates or authorship. Therefore, the terms 'data', 'document' and 'text' should be seen as practically interchangeable.

Extending the example of a collection of news articles, some derived rules could be:

if(ball AND racquet) OR (Wimbledon), then confidence("tennis" category) = 0.9
*confidence("tennis" category) = 0.3*ball + 0.4*racquet + 0.7*Wimbledon*

This task can also be further illustrated by the decision matrix shown in Table 2-1. In this matrix, rows $\{c_1,...,c_m\}$ represent predefined categories and columns $\{d_1,...,d_n\}$ represent the set of documents to be categorised. The values $\{a_{ij}\}$ stored in the intersecting cells represent the decisions to classify a certain document under a certain category, or not.

	d_1	d_2	d_3	...	d_n
c_1	a_{11}	a_{12}	a_{13}	...	a_{1n}
c_2	a_{21}	a_{22}	a_{23}	...	a_{2n}
...	...	...	...	...	...
c_m	a_{m1}	a_{m2}	a_{m3}	...	a_{mn}

Table 2-1 Classification decision matrix [19]

Furthermore, documents can either be assigned to exactly one category, or to multiple categories. The first case is referred to as *single-label* categorisation and implies non-overlapping categories, whereas second cases is referred to as *multi-label* categorisation and implies overlapping categories [20]. In most cases, a classifier designed for single-label classification can be used for multi-label categorisation, if the multiple classification decision is reorganised as a set of independent, single decisions.

Another important distinction is that of hard categorisation versus ranking categorisation [20]. Depending on the level of automation required, a classifier could either make a 1 or 0 decision for each a_{ij} or, instead, could rank the categories in order of their estimated appropriateness. This ranking could then assist a human expert to make the final, hard categorisation. In the case of a hard categorisation, it is crucial to choose an appropriate *threshold* value above which a decision of 1 can be made, depending on the level of certainty

Copyright © 2008 Capgemini – All rights reserved

required by the particular classification scenario. This threshold is also referred to as a confidence level. Techniques for choosing this value are further discussed in [20].

Information Retrieval (IR) was the first application of automated classification and motivated much of the early interest in the field. This has led to extensive research and ever more accurate techniques for categorising text documents. This research has led to more automation and less human interaction, through the application of machine learning techniques to the categorisation task. [19]

The traditional approach to document classification was to manually define a set of rules that would determine if a document should be classified under a certain category or not. These rules were created by human classifiers with expert knowledge of the domain. This approach suffered from the *knowledge acquisition bottleneck*, as rules had to be manually defined by knowledge engineers, working together with experts from the respective information domain. If the set of documents was updated to include new or different categories, or to port the classifier to an entirely different domain, this group would have to meet and repeat the work again. [19]

Since the late 1990s, this approach has been increasingly replaced by *machine learning* that uses a set of example documents to automatically build the rules required by a classifier [20]. The effort is thus no longer spent to create a classifier for each category, but rather to create a builder of classifiers, that can more easily be ported to new topics and applications.

> *"The advantages of this approach are an accuracy comparable to that achieved by human experts, and a considerable savings in terms of expert labour power, since no intervention from either knowledge engineers or domain experts is needed for the construction of the classifier or for its porting to a different set of categories" [20].*

The notion that automated classifiers attain levels of accuracy equal to those of their human counterparts might be better understood when we consider that neither of these attain 100% accuracy. It has been shown that human experts disagree on the correct classification of a document with a relatively high frequency, largely due to the inherent subjective nature of a classification decision. This is referred to as *inter-indexer inconsistency* [20]. Furthermore, "the degree of variability in descriptive term usage is much greater than is commonly suspected. For example, two people choose the same main key word for a single well-known object less than 20% of the time" [21].

This approach is also much more convenient for the persons supervising the classification process, as it is much easier to describe a concept *extensionally* than *intensionally* [20]. That is, it is easier to select examples of a concept than it is to describe a concept using words.

The machine learning approach relies on a corpus of documents, for which the correct classification is known. This corpus is divided in two, non-overlapping sets:

- *the training set*: a set of pre-classified documents, that is used to teach the classifier the characteristics that define the category (a category profile), and
- *the test set*: a set of documents that will be used to test the effectiveness of the classifier built using the training set. [19]

Copyright © 2008 Capgemini – All rights reserved

Furthermore, the training set can consist of both positive and negative examples. A *positive example* of category c_i is a document d_j that should be categorised under that category, therefore $a_{ij} = 1$. A *negative example* of category c_i is a document d_j that should not be categorised under that category, therefore $a_{ij} = 0$. [19]

Automated text classification was first introduced in the early 1960s for automatically indexing text documents to assist in the task of IR. Interest in this subject was initiated by the seminal research performed by M.E. Maron at the RAND Corporation [22]. In their paper, Maron introduced the idea of measuring the relationships between words and the categories they described. This was achieved using Shannon's Information Theory [23] and a prediction method similar to Naïve Bayesian Inference to select *clue words* that represented certain categories. Based on these clue words, Maron was then able to create a set of rules to automatically classify documents with an average accuracy of 84.6%.

In addition to automatic indexing for IR, other techniques have been developed and other applications for this technology have been found, including document filtering and routing [24], authorship attribution [25, 26], word sense disambiguation [27] and general document organisation.

Automatic indexing for IR was the first application of this automatic categoriser technology and where most research has been carried out. These systems consist of a set of documents and a *controlled dictionary*, containing keywords or phrases describing the content of the documents. The task of indexing the set of documents was to assign appropriate keywords and phrases from the controlled dictionary to each document in the set [19]. Controlled dictionaries are typically domain specific, such as the NASA or MESH thesauri. This was usually only possible with trained experts and was thus very slow and expensive.

Document filtering (sometimes referred to as document routing) "can be seen as a special case of categorisation with non-overlapping categories, [in other words] the categorisation of incoming documents in two categories, the relevant and the irrelevant" [19]. Document filtering is contrasted with typical IR, in that "IR is typically concerned with the selection of texts from a relatively static database, filtering is mainly concerned with selection or elimination of texts from a dynamic data stream" [24]. An example of filtering could be selecting relevant news articles regarding sports from a streaming newsfeed from the wire services, such as Reuters or Associated Press. In such a newsfeed, only articles identified as sports (or a specific sport or player) would be selected and the rest would be ignored or discarded. Another example could be the filtering of "junk" mail from incoming email as evaluated by [28].

Text classification techniques have been applied to the problem of determining the true author of a work of text by analysing known examples to create a "fingerprint" of an author and comparing this to the disputed work [29]. An interesting example of this problem is the controversy of whether or not certain sonnets attributed to William Shakespeare were, in fact, written by Christopher Marlowe. Indicating the difficulty of the task, there is even the Calvin Hoffman prize (approximately £1,000,000) for the person who can prove definitive authorship and thus settle this controversy.

Copyright © 2008 Capgemini – All rights reserved

Word sense disambiguation (WSD) is the task of finding the intended sense of an ambiguous word [19]. This is quite useful when certain words have several meanings or can form several different parts of speech. Specifically, ambiguous words can be seen as instances of *homonymy* or *polysemy*, which means the existence of two words having the same spelling or pronunciation but different meanings and origins, or the coexistence of many possible meanings for a single word or phrase.

For instance, in the English written language, the words *pine* and *cone* both have several different definitions. The word *pine* can be defined as 1) an evergreen tree with needle-shaped leaves, and 2) to waste away through sorrow or illness. Similarly, the word *cone* can be defined as 1) a cylindrical shape that narrows to a point, and 2) a fruit of certain evergreen trees. Separately, the intended definition of each word can only be guessed at; however, when used in combination (*pine cone*), the correct word sense becomes more obvious. [30]

WSD can be used to index documents by word senses rather than words or identify parts of speech (POS) for later processing. This has been shown to be both beneficial to the task of IR, as well as useless or even detrimental [27].

Document organisation is perhaps the broadest application for automatic categoriser technology. Organising documents into appropriate categories can be useful for many reasons, such as organising news articles [31] or patent applications [32].

Internet search engines can be seen as a special case of general document organisation, on a large scale with an inherently dynamic nature. This is probably the most visible and familiar application of classifier technology. Different search engines apply different classification techniques in different ways to improve the relevance of search results, from the PageRank [33] and topic classification used by *Google*, to the hierarchical directory maintained by *Yahoo!*. Other search engines, such as *Clusty* and *Webclust* automatically cluster web pages by topic, to offer search refinement. Further research in these fields is discussed in [34-37], the last of which approaches search as a distributed problem.

2.6. Information Lifecycle Management

Information Lifecycle Management (ILM) is a new field that hopes to handle information, such as text documents, differently according to the stage in its lifecycle. Specifically, an important goal is to organise documents for appropriate and cost effective storage. For instance, some documents should be stored such that they can be quickly retrieved, whereas other documents can be stored offline and offsite, resulting in a longer retrieval time at a lower cost. Classifying documents to map them to these storage classes can allow financial resources to be better aligned to this end.

ILM is based on the assumption that information changes value over time, as depicted in Figure 2-1. The most important factor in deciding the value of a document in this context is the time since creation and time since last access. Policies can be centrally created that automate the movement from documents from one storage category to the next, based on these attributes. For instance, as the relevance of a particular document increases, it can be moved to a high availability Network Attached Storage (NAS) device. When the value of the

Copyright © 2008 Capgemini – All rights reserved

document decreases, it can be moved to a slower and cheaper storage device, such as an array of hard drives or a CD-ROM archive. When the value of the document drops below some threshold, the document can be destroyed to prevent any unnecessary storage costs.

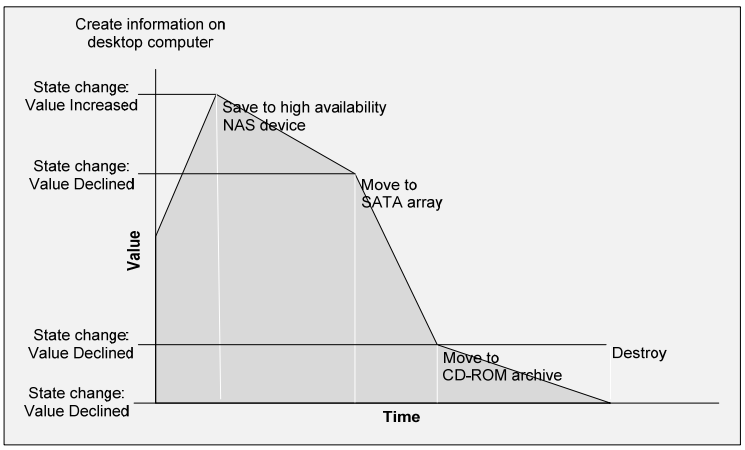

Figure 2-1 Lifecycle based on value over time [38]

According to Jan van de Ven (see Appendix A), an Enterprise Architecture Consultant at Capgemini BV, who specialises in ILM implementations, current products rely largely on document metadata, such as creation date, last access date and author. These products do not process document content with keyword parsing or statistical analysis, as the difficulty and complexity of such a system typically outweighs the benefits, thereby negating the business case.

In addition to the alignment of storage tiers, ILM products can integrate certain protections, such as integrity or confidentiality guarantees per classification or other services, such as document deduplication. Some implementations enter all documents into the system, whereas others leave the choice of inclusion to the document owner. This requires that users are trained to understand ILM and the appropriate decisions to take.

The EMC Corporation [39] proposes a more granular approach to information classification, beginning with the creation of *information groups*, based on the business value or the regulatory requirements. These groups contain data files, file systems and databases that contain application information. Separate ILM policies can then be created for each of these groups.

An innovative method for automatically determining and even predicting information value is proposed by [40]. The approach involves combining usage over time statistics with time since last use data to measure a documents apparent value. Furthermore, once the "important" documents are known, these can be analysed to find attribute patterns of high value classes. "For instance, if it is known that files of particular types and from particular groups of users are valuable, whenever a file with those characteristics is created, the system can automatically infer its value class and apply appropriate management policies" [40]. This indicates a step towards a more fully automated classification mechanism, but such tools are not yet widely available.

Copyright © 2008 Capgemini – All rights reserved

2.7. CONCLUSION

This chapter has introduced the key concepts surrounding the need for security classification and some of the automated classification techniques currently available. The trend of de-perimeterisation is driving the need for better data protection that is both appropriate and specific to each object of information. Identifying and labelling data with appropriate security classifications is required to control access and protect confidentiality. As this process of identifying and labelling documents must scale to the corporate environment, techniques are required to automate and simplify this daunting task. Automated classifiers exist and are constantly being improved in fields, such as IR and ILM, indicating their usefulness and possible application to other fields, such as security classification.

Copyright © 2008 Capgemini – All rights reserved

3. SECURITY CLASSIFICATION IN PRACTICE

This chapter will describe the current situation with regard to security classification in practice in the private sector. We will begin by identifying the driving factors of data protection and the shift towards data-centric security and, finally, giving an overview of the current state of classification, including different classification policies used.

3.1. MOTIVATIONS AND TRADE-OFFS OF DATA SECURITY

In the government environment, the strongest motivation for data security is the protection of national security, as is described in Chapter 5. The main trade-off is that between the preservation of national security and the importance of freedom of information in an open society. This can result and justify security measures that require large costs in terms of money, time and decreased usability. While the military can serve as a useful example and reference for security classification, this research is more concerned with the private sector, which has other motivations and trade-offs.

It can be argued that there is much interest for data protection in the private sector, as well. However, the trade-off is mainly made between the cost of security in terms of money, resources and decreased usability, and benefits, in terms of reducing security risks. Perhaps, one of the more difficult issues of implementing a model of automated security classification will likely be proving the business benefits outweigh the costs. Furthermore, this interest is not driven by the preservation of national security, as in the governmental approach described in Chapter 5. The need for data protection in the private sector is instead driven by several other factors, namely compliance, reputation and competitive advantage.

Private business is subject to two forms of compliance: government and non-governmental. Governmental compliance is mandated by law and can be punished by fines or legal action. Examples of these are privacy laws or health privacy laws, such as the Health Insurance Portability and Accountability Act of 1996 (HIPAA) [41] in the United States or European Union Directives regarding privacy and data protection [42,43]. HIPAA was designed to protect individually identifiable health information (PII), such as an “individual’s past, present or future physical or mental health or condition.” This includes some common identifiers, such as name, address, birth date and Social Security Number (SSN). This information can be disclosed only when “de-identified” by removing these common identifiers. The Jericho Forum suggests that such PII can be further sub-categorised as follows [9]:

- Business Private Information (BPI), such as your name on a business card
- Personal Private Information (PPI), such as home address, date of birth, bank details
- Sensitive Private Information (SPI), such as sexual orientation, medical records

Compliance is also required for some non-governmental regulation, such as by the Payment Card Industry. In the new Payment Card Industry Data Security Standard [44], several guidelines are given regarding the secure handling of credit card information. Lack of compliance with these regulations can result in “heavy fines, restrictions or permanent

Copyright © 2008 Capgemini – All rights reserved

expulsion for card acceptance programs." This new security standard provides general guidelines, such as storing only the absolute minimum amount of data that is required, but also specific guidelines, such as not storing the full contents of the magnetic strip, card-validation code or personal identification number (PIN). When data must be stored, such as the personal account number (PAN), guidelines are given that require partial masking when displayed and encrypting when stored.

The expectation of compliancy becomes more complicated when we consider the current market trends of outsourcing and collaboration that inevitably leads to the transfer of valuable, perhaps regulated data, outside the control of the responsible company. This aspect of external risk could further drive the need for non-governmental, regulating bodies, such as the PCI initiative mentioned above, as well as new tools to prove and maintain compliance restrictions.

Another external motivation for data protection is the possible damage to the reputation of the corporation in the eyes of the public that can result in loss of current and future revenue. According to a 2007 study of the costs of data breaches [45], "lost business now accounts for 65 percent of data breach costs." Furthermore, data breaches by third-party organisations such as "outsourcers, contractors, consultants, and business partners" were "more costly than the breaches by the enterprise itself."

Finally, competitive advantage drives the need from data protection from within the enterprise. In order to remain competitive, enterprises must prevent the disclosure of certain information to their competitors. The exact information that represent trade secrets or intellectual property can be different for each enterprise, but the criteria for determining which data, if disclosed, could damage the competitive advantage can be somewhat standardised. As Dirk Wisse of Royal Dutch Shell (see Appendix A) stated regarding Shell's information security strategy, this involves a top-down approach of identifying the important business processes, the applications that support these processes and, finally, the systems and data that support these applications.

3.2. The Role of Classification

Data-centric security was introduced in Chapter 1, focuses on securing data itself rather than the underlying infrastructure. It was shown that this is being motivated by increased regulation and confidentiality requirements. The current approach results in security mechanisms that do not follow the data when it moves from one device to another, or leaves a corporate domain. This point was further illustrated by examples of data leaks that could have been better prevented by such data-centric security mechanisms [2, 3].

The need for data-level security mechanisms was also reiterated in the context of the de-perimeterisation efforts of the Jericho Forum introduced in Chapter 2. As business shifts towards a more open and mobile data sharing environment, controls must be in place that can offer appropriate and specific protections for sensitive data, independent of the underlying infrastructure.

The solution proposed by the Jericho Forum is similar to the Digital Rights Management (DRM) systems used for years for media distribution [9] or policy enforcement

Copyright © 2008 Capgemini – All rights reserved

mechanisms, such as Trishul [46]. The first generation of these systems were aimed at preventing unauthorised duplication and proliferation of data, such as audio files. Unfortunately, most DRM implementations all suffer from a flaw, known as the *analogue hole* [47]. This occurs when protected media is converted to analogue form for use, such as sound or image, and are no longer protected by digital countermeasures. Examples of the analogue hole include re-recording audio or video files as they are being played with a separate program or external recording device.

The original concept of DRM has been redesigned for the protection of confidential corporate information that is concerned more with the ability to read or modify a digital file, rather than its duplication. This new form of digital protection is referred to as Enterprise Rights Management (ERM). Such a system uses encryption and access control lists to ensure that some (sensitive) documents are not viewed by some (unauthorised) users.

This approach is also referred to as Persistent Information Security [48]. It differs from the original DRM model in that control mechanisms remain in place, as opposed to only protecting the file until it is "unlocked" by the first user. Instead, the protected file can be copied and redistributed without the original information custodian losing control over usage. Such mechanisms can offer confidentiality protection for sensitive data, but it must first be determined if certain data is private, valuable or dangerous in the wrong hands, and thus warrants such protections. In other words, data must first be classified.

It is argued in [1] that this starts with information classification, based on its level of sensitivity, into multiple classes. Companies need to extrapolate an appropriate classification scheme from their business processes and then inform users (data owners) how to classify, label and handle data accordingly. Furthermore, [1] suggests that automated data classification tools would be "invaluable in this step."

The need for data classification was reiterated by [49,50] as a result of increasing compliance requirements and the increasing trend of critical data being stored on mobile devices. In order to prevent and respond better to security breaches, data should in turn be classified in terms of privacy restricted. This is especially important when new government regulation requires companies notify customers when personal information is leaked, resulting in financial damages from fines and bad reputation. Furthermore, data should be classified in terms of mission-critical to assure business continuity in the event of large-scale disaster.

3.3. Classification in Practice

According to a survey performed in 2006, almost half of the 571 companies contacted have no current data classification scheme to protect sensitive information and have no plans on implementing such a system in the near future [49]. The findings of this survey are summarised in Table 3-1. An additional survey [51] performed in 2008 with 470 companies revealed similar results, as depicted in Figure 3-1. The implication that roughly half of the corporate world is neither currently nor planning to classify information assets, reveals how far away the realisation of a data-centric security model actually is. As such, these

Copyright © 2008 Capgemini – All rights reserved

corporations will continue to face the challenges that are inherent in a security model focused on a secure perimeter and infrastructure, as described in Chapters 1and 2.

Regarding the companies that are either currently using or planning a classification regime, the understanding is that this will be largely a manual process, where either users (data owners) or security officers have the task of marking individual assets, such as documents, systems or applications, with their appropriate security classifications.

Are you using data classification schemes to categorize your firm's sensitive information?	
Yes, we are using data classification for security.	31%
No, but we are planning to implement this technology in the near future.	19%
No, we have no plans at this time to implement the technology.	46%
Don't know.	4%

Table 3-1 ComputerWorld 2006 survey [49].

Figure 3-1 Forrester Research 2008 survey [51].

Manual classification has several inherent problems, that have been identified and addressed in the field of classification for IR, and have consequently led to the development of automation technologies [20]. These are namely, cost and consistency. Cost can be measured in this context, in terms of time and money. Manual classification is generally a slow process and requires trained experts in the relevant domains. Due to this limitation, it also scales poorly when faced with the magnitude of documents circulating in the corporate world. Furthermore, there is the problem of consistency of classification. Even trained experts can classify the same document differently. This is referred to as *inter-indexer inconsistency* in the field of IR [20].

In the case of a large backlog of unclassified documents, a slow manual classification process can create a *knowledge acquisition bottleneck* [20]. In the case of security classification, this could mean that unclassified documents could not be accessed in a repository until they were classified. Depending on the frequency and need to access as yet unclassified documents, this could negatively impact many other facets of normal business operations.

According to Adrian Seccombe (see Appendix A), Chief Information Security Officer at Eli Lilly, a classification is essential to preventing the leakage of sensitive information. Eli Lilly has firsthand knowledge of the consequences of data leakage, specifically involving

Copyright © 2008 Capgemini – All rights reserved

information protected by privacy laws. Several well-publicised instances damaged the reputation of the company and resulted in government sanctions.

As a reaction to these violations, Eli Lilly is now in the process of implementing a corporate wide classification scheme. This follows the so-called "traffic light protocol" as depicted in Figure 3-2. This classification will take into consideration the three main pillars of security, *Confidentiality*, *Integrity* and *Availability* (CIA), as well as the concept of identity, something quite relevant in determining privacy requirements. In the proposed scheme, users will be solely responsible for the appropriate, manual classification of their documents. In order to facilitate this process, Eli Lilly has undertaken a massive security awareness program, so that users fully understand the meaning of each classification and the consequences of improper classification. In short, classification is a human-driven process, that is supported by business processes, and in turn may be supported by technology. Some automated search tools were used to perform a system wide audit which revealed that some sensitive was inappropriately located and at risk of exposure or loss. The results of this project have revealed the seriousness of the problem, as well as the usefulness of automated tools, backed up with trained professionals.

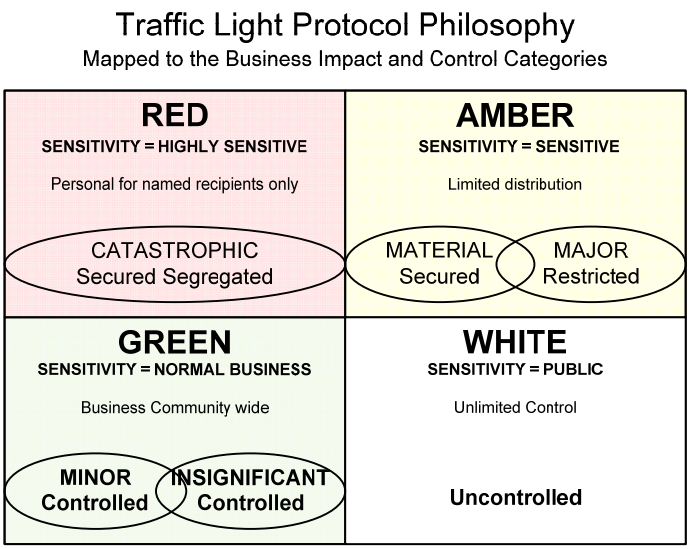

Figure 3-2 Traffic Light Protocol as used by Eli Lilly.

There is also an active classification policy at Shell, according to Dirk Wisse (see Appendix A). This involves a top-down approach to identify and classify sensitive systems and data according to a four tier classification based mainly on confidentiality. This is currently evolving the CIA security classification, in order to encompass the other security aspects. Regarding documents, this ultimately involves users, in this case the owners of the data, manually classifying documents at the time of their creation if they feel it necessary. However, no strict guidelines or mechanisms are currently in place at the document level, as this would meet with resistance from users.

A similar classification policy is followed by Rabobank, according to Paul Samwel (see Appendix A). This classification policy is also based on the CIA scheme, and is focused largely on processes, applications and ICT components rather than on individual documents.

Copyright © 2008 Capgemini – All rights reserved

Hans Scholten (see Appendix A) was involved with a classification project at Thales Netherlands during which data had to be classified and moved to separate networks in order to comply with Dutch military and NATO information security standards. This involved dividing the network into two logical partitions: *Red* and *Blue*. The Red network contained all highly secret information and the Blue network contained lower level information. Access to the Red network was then controlled by brokers in a third network, *Green*. After the separation, all documents, applications and components were classified and moved to the appropriate network. For example, the source code of several applications was Red, but the compiled binary was Blue. This involved working closely together with data owners and additional security officers aware of the classification guidelines. Document classification was almost entirely a manual operation, but some tools were used for searching for keywords, such as a previous classification tag on the first line of a document. This was a slow process manually performing this transformation to a classified system. However, this process was only performed once, so the difficulties of manual classification were perceived to be less than those of building and testing an automated tool for the same task.

3.4. CONCLUSION

In this chapter we have studied the realities of security classification in practice in the private sector. We have listed the motivations and trade-offs of data security, including compliance regulation and protecting reputation and competitive advantage. Furthermore, we discussed the importance of classification as the first step towards comprehensive data protection. Finally, we investigated security classifications in practice in the private sector by means of interviewing security professionals from different industries, including energy, financial, pharmaceutical and technology.

Copyright © 2008 Capgemini – All rights reserved

4. CLASSIFICATION REQUIREMENTS AND TECHNOLOGIES

In this chapter, we will discuss two main elements that are needed to develop a model for automated security classification, namely requirements and technologies. First, we will examine that factors that should be taken into consideration when making a security classification decision. This will help to identify the elements that must be extracted from the documents and stored for subsequent classifications. Secondly, we will describe the current classification technologies currently available in order to gain awareness of the different possible methods, as well as their relative strengths.

4.1. SECURITY CLASSIFICATION DECISION FACTORS

In order to identify the requirements of the ASC model, we should first understand what elements it should provide to the subsequent security classification decision. This insight can be approached by understanding what factors are taken into consideration when performing security classification. We will focus mainly on official published guidelines, and will supplement this with input from professionals in the field. Our goal is to identify the main factors that influence the decision to classify a document into one security level instead of another. With this information we can begin to identify which of these elements should therefore be included in the ASC model.

According to our preliminary research, it appears that there are two main areas of security classification: the government (intelligence, military, military contractors) and the private sector (banking, commerce, and so on). Due to the age, quantity and accessibility of government sources on this subject, more of our initial research has been drawn from this area. It is important to note that despite the fact that both of these areas are interested in data protection, the reasons driving this interest are not necessarily the same. In the private sector, preventing unauthorised disclosure of sensitive information is performed namely to protect a competitive advantage or comply with government regulations. In contrast, governments are more concerned with protecting national security. Despite these differences, lessons can be learned from the approaches in both of these areas.

According to the United States Department of Defense Information Security Program [52], the main motivation behind security classification of government information is the preservation of national security. Three main classification levels are recognised, as shown in Table 4-1, based on the severity of possible damage to national security. All documents that are not specifically assigned to one of these three are then considered *Unclassified*.

Top Secret	Shall be applied to information, the unauthorised disclosure of which reasonably could be expected to cause **exceptionally grave damage** to the national security that the original classification authority is able to identify or describe.
Secret	Shall be applied to information, the unauthorised disclosure of which reasonably could be expected to cause **serious damage** to the national security that the original classification authority is able to identify or describe.
Confidential	Shall be applied to information, the unauthorised disclosure of which reasonably could be expected to cause **damage** to the national security that the original classification authority is able to identify or describe.

Table 4-1 Government security classifications with rationale [52].

Copyright © 2008 Capgemini – All rights reserved

Regarding the decision of when and which classification to apply, the National Industrial Security Program Operating Manual states that:

> *"a determination to originally classify information may be made only when (a) an original classification authority is classifying the information; (b) the information falls into one or more of the categories set forth in [Executive Order 12958]...; (c) the unauthorized disclosure of the information, either by itself or in context with other information, reasonably could be expected to cause damage to the national security...; and (d) the information is owned by, produced by or for, or is under the control of the U.S. Government" [53].*

These steps are illustrated in Figure 4-1.

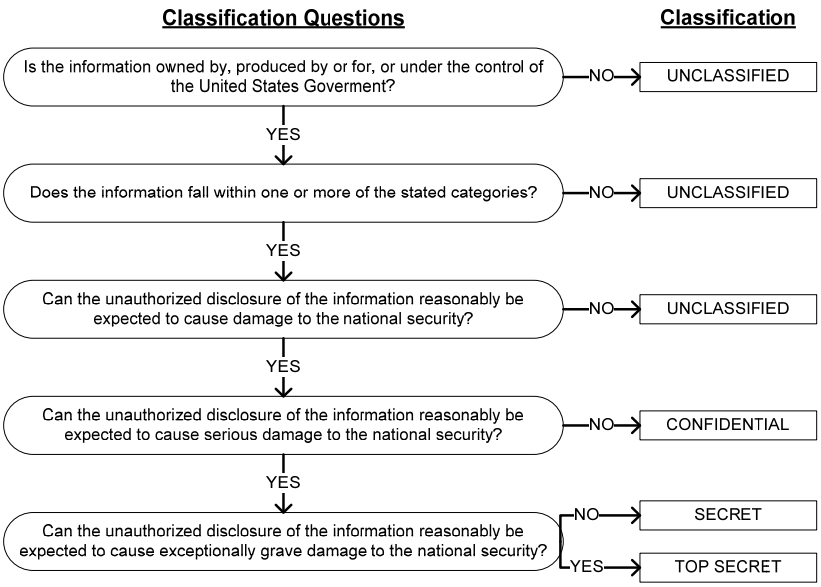

Figure 4-1 Decision tree for security classification [54].

The Executive Order [55] elaborates these points. An original classification authority is someone who is authorised in writing by the President to determine classification levels. The categories mentioned are:

(a) military plans, weapons, or operations;
(b) foreign government information;
(c) intelligence activities (including special activities), intelligence sources or methods, or cryptology;
(d) foreign relations or foreign activities of the United States, including confidential sources;
(e) scientific, technological, or economical matters relating to the national security;
(f) United States Government programs for safeguarding nuclear materials or facilities, or
(g) vulnerabilities or capabilities of systems, installations, projects or plans relating to the national security.

The Executive Order also specifies a temporal component to classification [55]. This temporal component states that a specific date should be set by the original classification authority for declassification. This date shall be "based upon the duration of the national

Copyright © 2008 Capgemini – All rights reserved

security sensitivity of the information." If no such date is explicitly stated, the default period is 10 years from the date of the original decision. However, even this default value can be extended if disclosure of the information in question "could reasonably be expected to cause damage to the national security for a period greater than [10 years]..." Additionally, this extension can be indefinite if the release of this information could "reasonably be expected" to have a specific effect. The effects listed include revealing an intelligence source, damaging relations with a foreign government, violating an international agreement and impairing the ability to protect the President. Some of the effects listed are clearly easier to quantify than others.

After classification, the document must be marked with additional security metadata, according to the following specification [55]:

(a) one of the three classification levels;
(b) identity of the original classification authority;
(c) document origin;
(d) date for declassification (or explanation for exemption); and
(e) concise reason for classification.

In addition to classifying the document as a whole, it is also possible to classify the information contained in the document at a finer level of granularity. This includes classification for portions, components, pages and, finally, the document as a whole [53]. In this case, each section, part, paragraph or similar portion of the document is classified according to the applicable security guidelines. Each major component, such as annexes, appendices or similar component of the document receives a classification equal to the highest classification found in that component. Similarly, page and overall classifications are computed as equal to the highest level of classification found therein.

It is also explicitly stated that unclassified subjects and titles shall be selected for classified documents, if possible [53]. Although not stated explicitly, one might assume that this guidance is meant to avoid the leakage of classified information to those unauthorised individuals who are not able to read the contents, but can derive enough classified information from the title or subject alone.

In most cases, a security classification guide is the written record of an original classification decision regarding a system, plan, program or project, that can be used to guide future classifications in that context [52]. These guides should 1) identify the specific items, elements or categories of information to be protected; 2) state the specific classification assigned to each of those items, elements or categories; 3) provide declassification instructions, usually based on either a date for automatic declassification or a reason for exemption from automatic declassification; 4) state the reason for the chosen classification for each item, element or category; 5) identify any special caveats; 6) identify the original classification authority; and 7) provide contact information for questions about the guide [52].

The Department of Defense Handbook for Writing Security Classification Guidance [54] offers broad guidelines to be followed when writing these security classification guides.

Copyright © 2008 Capgemini – All rights reserved

These include 1) making use of any existing, related guidance; 2) understanding the state-of-the-art status of scientific and technical topics; 3) identifying the elements (if any) that will result a national advantage; 4) making an initial classification based on general conclusions; 5) identifying specific items of information that require separate classification; 6) determining how long a classification must continue; and finally, 7) writing the guide to offer guidance to future classification decisions in this context [54].

The crucial part of a classification guide is accomplished in step 5, where the specific elements of information requiring security protection are identified. It is crucial that the levels of classification of these elements are precisely and clearly stated. Broad guidance at this stage will create ambiguity that will lead to interpretations not consistent with the original intent. Some concrete examples of this stage from [54] are given below:

- Unclassified ("U") when X is not revealed;
- Confidential when X is revealed;
- Secret when X and Y are revealed.

In addition to the original classification, there are other instances when classification or re-classification is required; namely derivative, association and compilation. Derivative classification is the "incorporation, paraphrasing, restating or generating in new form information that is already classified" [55]. Thus, if a new document is created that makes either full or partial use of information that is already classified, the classification of the new document should "observe and respect the original classification decisions" [55]. The most common approach is to preserve any original classifications in the newly created document. Furthermore, if previously unclassified documents (or portions of documents) are recombined in such a way that reveals an additional association, that meets the guidelines previously stated, the new document should be reclassified accordingly [55].

Classification by association is the classification of information due to its "association with other information implicitly or explicitly reveals additional information that is classified" [56]. For instance, a seemingly unremarkable order of off-the-shelf parts becomes more informative if the head of the weapons division is listed as having personally placed the order.

Compilation classification is the reclassification of compilations of previously unclassified information, when the compilation reveals new information, such as associations or relationships that meet the standards for original classification [55]. As a rule, compilations of unclassified information should remain unclassified, in most cases. This is important for two reasons: 1) avoiding classification costs when the same information could be easily obtained by independent efforts, and 2) maintaining the credibility of the classification effort, by avoiding seemingly pointless classification [56]. An example of this situation is when a new document is created by listing all unclassified projects over the past decade. While each project name and description is unclassified, it might reveal certain trends in development that should be classified. However, if the list can easily be reproduced without significant time or costs, the list should remain unclassified.

Copyright © 2008 Capgemini – All rights reserved

The exception to this rule is when "substantive value" has been added to the compilation in one of two forms: 1) expert selection criteria, or 2) additional critical components [56]. In the first case, if the expertise of the compiler was required to prepare the compilation, by selecting only specific information, this might reveal which parts of the original information is important. In the second case, if the compiler added additional expert comments about the information, such as its accuracy, this might also reveal additional information. In either of these cases, the additional information must be reviewed and classified according to the steps of original classification.

In 2003, the National Institute of Standards and Technology (NIST) produced a document providing "standards to be used by all federal agencies to categorise all information and information systems... based on the objectives of providing appropriate levels of information security according to a range of risk levels" [57]. This document established three security objectives: Confidentiality, Integrity and Availability, as well as three levels of potential impact: Low, Moderate and High. Together, these form a classification matrix shown in Table 4-2.

	POTENTIAL IMPACT		
Security Objective	**LOW**	**MODERATE**	**HIGH**
Confidentiality Preserving authorised restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information	The unauthorised disclosure of information could be expected to have a **limited** effect on organisational operations, organisational assets, or individuals.	The unauthorised disclosure of information could be expected to have a **serious** effect on organisational operations, organisational assets, or individuals.	The unauthorised disclosure of information could be expected to have a **severe or catastrophic** effect on organisational operations, organisational assets, or individuals.
Integrity Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.	The unauthorised modification or destruction of information could be expected to have a **limited** adverse effect on organisational operations, organisational assets, or individuals.	The unauthorised modification or destruction of information could be expected to have a **serious** adverse effect on organisational operations, organisational assets, or individuals.	The unauthorised modification or destruction of information could be expected to have a **severe or catastrophic** adverse effect on organisational operations, organisational assets, or individuals.
Availability Ensuring timely and reliable access to and use of information.	The disruption of access to or use of information or an information system could be expected to have a **limited** adverse effect on organisational operations, organisational assets, or individuals.	The disruption of access to or use of information or an information system could be expected to have a **serious** adverse effect on organisational operations, organisational assets, or individuals.	The disruption of access to or use of information or an information system could be expected to have a **severe or catastrophic** adverse effect on organisational operations, organisational assets, or individuals.

Table 4-2 Potential impact definitions for each security objective [57].

Rather than focussing on the subject, this framework categorises information by its information type, such as medical, financial or administrative information. Security categories (SC) are expressed in the following format, where *impact* can be Low, Moderate, High, or Not Applicable. The generic format and examples for public and administrative information are shown in Figure 4-2.

Copyright © 2008 Capgemini – All rights reserved

SC information type = {(**confidentiality**, *impact*),(**integrity**, *impact*),(**availability**, *impact*)}
SC public information = {(**confidentiality**, NA),(**integrity**, Moderate),(**availability**, Moderate)}
SC administrative information = {(**confidentiality**, Low),(**integrity**, Low),(**availability**, Low)}

Figure 4-2 NIST security categories.

In 2004, NIST released a two-volume document providing guidelines for mapping information types to security categories. The first volume includes general steps that should be taken, including an initial classification based on several general factors that determine the impact of a breach of any of the three security objectives [58]. This document identifies two major sets of information types: 1) Mission-based, that are specific to individual departments and 2) Administrative and management, that are more common across different departments. The second volume list more specific guidelines in the form of appendices per information type [59] that alone constitute more than 300 pages, alluding to the complexity and context dependency of the task.

According to NIST, the first step in the classification process is "the development of an information taxonomy, or creation of a catalogue of information types" [58]. This approach can be followed by any organisation by first documenting the major business and mission areas, then documenting the major sub-functions necessary to each area, and finally defining the information type(s) belonging to those sub-functions. Some of the common information types have been pre-classified by NIST for both mission-based and administrative information [59]. A summary of these classifications is given in Appendix B.

Guidelines for security classification in the private sector are understandably less standardised and less accessible than in the government sector. When these guidelines exist, they are not made easily available outside their respective domain. As our purpose here is only to define the most generic decision factors of a security classification, we will extrapolate from as many sources as possible, with the understanding that most policies are one-offs that only specifically apply to their original domain.

Universities have been found not only to provide clearly defined classification guidelines, but also to make these freely available outside their domain. The official data classification security policies were consulted from George Washington [60], Purdue [61] and Stanford [62] Universities. These universities use similar classification levels, such as *Public*, *Official Use Only*, and *Confidiential*. Additional examples of restricted data are shown in Table 4-3.

Control Objectives for Information and related Technology (COBIT) is an industry standard IT governance framework used by many enterprises to align their control requirements, technical issues and business risks. This framework also recommends that companies implement a data classification scheme to provide a basis for applying encryption, archiving or access controls. "This scheme should include details about data ownership; definition of appropriate security levels and protection controls; and a brief description of data retention and destruction requirements, criticality and sensitivity" [63].

In 2005, the International Organisation for Standardisation (ISO) and the International Electrotechnical Commission (IEC) published standards for information security in the form

Copyright © 2008 Capgemini – All rights reserved

of [64] and [65]. These documents briefly mention the benefits of a data classification scheme to "ensure that information receives an appropriate level of protection" [64]. No concrete examples or guidelines are given for the creation of a classification scheme or the determination of proper classification. The only information provided states that a classification policy should consider the "value, legal requirements, sensitivity, and criticality to the organisation" of the information, as well as that information "often ceases to be sensitive or critical after a certain period of time" [65].

HIPAA: Protected Health Information	Patient name, address, telephone number, e-mail address, social security number (SSN), account number, vehicle identification number, biometric identifiers, full face images and any other unique identifying number
FERPA: Student Records	Grades, Transcripts, enrolment information, financial services information, credit card or bank account numbers, payment history, financial aid information and tuition bills
Donor Information	Name, graduation information, credit card or bank account numbers, SSN, amount donated, contact information and employment or medical information
Faculty/Staff Housing	Name, credit rating, income information and loan application data
Research Information	Private funding, human subject and lab animal care information
General Information	Confidential legal information
Employee Information	Performance reviews, disability information and a combination of name and other identifiable attribute, such as SSN, date of birth, address, etcetera
Business Data	Credit card numbers with or without expiration dates, bank numbers, SSN or Taxpayer Identification Number and contract information
Management Data	Annual budget information, faculty annual conflict of interest disclosures, university investment information and non-anonymous faculty course evaluations

Table 4-3 Examples of restricted data [62].

The SANS Institute created a template for classifying information based on its sensitivity. This template establishes to main classifications: *Public* and *Confidential*. Public information can be freely shared with anyone without any possible damage to the company. Confidential is all information that is not public. A subset of this classification is Third Party Confidential, that is "confidential information belonging or pertaining to another corporation which has been entrusted to [this company] by that company under non-disclosure agreements and other contracts" [66]. This policy further specifies three levels of sensitivity pertaining to confidential information: Minimal, More and Most Sensitive. The SANS sensitivity to information mapping is shown in Table 4-4.

Minimal Sensitivity	General corporate information, some personnel and technical information
More Sensitive	Business, financial, technical, and most personnel information
Most Sensitive	Trade secrets & marketing, operational, personnel, financial, source code & technical information integral to the success of our company

Table 4-4 Sensitivity to information mapping [66].

Using the classification guidelines identified above, from both the governmental and private sector, we have identified the following factors that are relevant to a security decision, and therefore must be incorporated into the ASC model.

Categories / topics – The specific category or topic can be a very important factor in assigning a security classification. This was shown in both the governmental

Copyright © 2008 Capgemini – All rights reserved

classification guidelines, as well as those of the private sector. A specific list of categories/topics could then be stored in the security policy repository (not covered in this dissertation) and referenced for the final security classification. This should accommodate multiple categories/topics in the case that classification rules consider depend on multiple items, such as "secret when X and Y are both revealed."

Date of creation – The date of document creation is one of the most important attributes in determining the time until the document is either declassified or reclassified (at a lower level). Unless otherwise specified, the default duration of classification (or retention) can be stored in the security policy and combined with the date of creation to determine the date of declassification, reclassification, or perhaps even destruction. Additionally, rules could be defined in the security policy for classification durations per category or topic.

Original classification – Some security classification decisions are predicated solely on the fact that the data owner or other authorised person has already made a security decision. This original classification should be taken into consideration in further classification decisions, if not simply honoured above all other factors. Clearly, this information will not be present for all, or even many, of the documents, but when present, this can impact the final classification decision. This information can also be useful in the case of derivative or compilation classification.

Data owner – The original author of the document can also influence the security classification decision. In the case of classification by association, some data producers tend to produce more classified data than others. For instance, the research and development department might produce more intellectual property and other business confidential data than the marketing department. In the case of a role-based classification policy, in which all users having a certain role (board of directors, help desk, human resources, and so on) are more likely to produce information at a certain classification, the data owner attribute would be used to lookup the respective role or department and apply the respective classification.

Document type – Insofar as it can be derived, the document type can be used to assign a particular security classification, as suggested by NIST. This can involve the document format, such as a Word document or PowerPoint presentation, but more to the point, this can involve standardised documents, such as loan applications, financial reports, medical records, and so on. This would involve creating a taxonomy of all document types in the organisation and assigning a security classification to each one based on the level of damage that can be caused by unauthorised disclosure, that can then be selected and applied based on this attribute.

Compliance – If a certain term in a document violates a compliance obligation to either government legislation or private contracts, this must be taken into account when assigning a security classification. This information should be supplied by the compliance parser component of the model. Furthermore, it might be useful to assign a sliding scale of compliance infringement, such as from one to ten, rather than simply a binary flag indicating either total violation or total compliance. For instance, some

Copyright © 2008 Capgemini – All rights reserved

violations could require fewer safeguards than others, as some leaks will lead to financial damages and others will simply lead to complaints. The compliance parser should provide a level of (suspected) violation so that the security policy repository can make a better classification decision. It might even be useful to include the type of violation, in addition to the severity, such as 'HealthInformation:4' or 'PCI:9.' Certain compliance violations, such as PCIDSS [44], require that certain information not be stored at certain locations, such as unprotected (uncertified) servers. This element must also be preserved by in the final compilation of metadata.

4.2. PARSING TECHNOLOGY

Parsing text documents involves scanning natural language text for terms or patterns of text that could represent an important element. An element is deemed important if it matches an entry in a predefined dictionary, such as Personally Identifiable Information (PII) and Payment Card Information (PCI), as discussed in Chapter 3. Perhaps one of largest implementations of this technology was accomplished by the National Security Agency (NSA) with their unconfirmed ECHELON program [67]. This program involves several countries intercepting multiple channels of communication, such as satellite data, voice and fax messages, converting these to a machine-readable format and, finally, scanning this data for keywords, as defined in the ECHELON Dictionary. Parsing text is a relatively cheap process in terms of computational requirements, as compared to the more advanced statistical analysis discussed in the next section, making this technology still feasible despite the high workload.

The process of parsing can involve several different steps and techniques. The basic approach to text parsing is to search text for specific text strings that match entries in a defined dictionary. If a match is detected, a flag is raised. This approach is used by [68] to detect PII in documents. Their proposed tool automatically generates the dictionary by harvesting potentially compromising strings both the local workstation and the domain controller. This includes names, IDs, computer names, organisational names, e-mail addresses, mailing addresses and telephone numbers. Entire documents can then be scanned to determine if they contain any of these elements.

In addition to simple text string search, regular expressions can be used to detect certain patterns. This enables the parser to detect not only specific, predefined strings, but also new strings that match a certain format. By adding wildcard functionality, regular expressions can detect combinations of words that standard keyword searches world miss. For instance, this can be used to detect numbers in the form of a Social Security Number (SSN) despite this specific number not being listed in a predefined dictionary. Additionally, using a wild card could detect when certain elements are used in combination. For instance, an SSN could be detected if the pattern '[0-9][0-9][0-9]-[0-9][0-9]-[0-9][0-9][0-9][0-9]' were detected, where '[0-9]' can be any single numerical digit. Company specific patterns could be detected using customised regular expressions, such as detecting combinations of known customer names and patterns matching SSNs.

Copyright © 2008 Capgemini – All rights reserved

In addition to detecting numerical sequences that resemble sensitive information, additional algorithms can be used to validate and distinguish actual sensitive numerical sequences. For instance, the Luhn checksum algorithm [69] can validate credit card numbers.

Additional linguistic analysis can be performed to assist the previous steps. This can include Part of Speech (POS) tagging to identify nouns, such as names of persons or products, as was introduced in Chapter 2.

4.3. Automated Text Classification Methods

The process of automated classification traditionally follows several steps, including 1) document indexing, 2) dimensionality reduction (feature extraction or selection) and finally 3) classification. For each of these steps, several methods are available.

Documents cannot be directly interpreted by a classifier algorithm; therefore, it is first necessary to convert documents into a compact representation. This usually involves converting a text document into a vector of weighted index terms, with weights ranging between 0 and 1. This is referred to as the *bag of words* approach [19]. Thus, documents are represented by vectors of terms a_{ik}, where a_{ik} is the weight of word i in document k [70]. Consequently, these vectors are combined for collections of documents to form a term-by-document matrix.

In most cases, these index terms are actual words from the document. Experiments have also been performed using phrases instead of words. These phrases have been both syntactical, as in phrases from language, and statistical, as in words that coincidentally occur together. Using phrases instead of words for the index terms has had discouraging results, probably due to the fact that "although indexing languages based on phrases have superior semantic qualities, they have inferior statistical qualities with respect to word-only indexing languages" [20].

The weights of features (sometimes referred to as terms) can also be computed using different methods, but most methods are based on the *word frequency*, where f_{ik} is the frequency of word i in document k. The guiding principle in term weighting comes from originally from Claude Shannon's Information Theory regarding entropy [22]. This theory provides the foundation for measuring how much information is carried by each unit of communication. For instance, knowing how many words a person must clearly hear during a noisy conversation to understand the core message of the speaker. This theory has provided two principles for term weighting:

- the more times a word occurs in a document, the more relevant it is to the topic of the document, and
- the more times the word occurs throughout all documents in the collection, the more poorly it discriminates between documents [70].

The simplest method is *Boolean weighting*, where a weight can only be 0 or 1. A value of 0 indicates that the word does not appear in the document, whereas a value of 1 indicates that the word appears at least once in the document [70]. Another simple approach is *word*

Copyright © 2008 Capgemini – All rights reserved

frequency weighting, in which the weight is equal to the exact number of times a word is used in document [70].

However, these first two methods do not embody the second principle established above, concerning word usage across the entire document collection. More elaborate approaches take this *document frequency* into consideration. This is the number of documents in the collection in which a term occurs. The most commonly used term weighting function that uses document frequency is the *term frequency inverse document frequency* (*tfidf) weighting* function. In this function (see Appendix C), f_{ik} is the number of times term i occurs in document k (word frequency), N is the total number of documents in the set and n_i is the number of documents in the set that contain at least once instance of term i.

Further refinements of this formula have been proposed to compensate for documents of different lengths (*tfc*) or large differences in word frequency (*ltc*) and to use more sophisticated entropy weighting. An overview of these formulas is given in Appendix C.

In most cases, these terms are actual words from the documents, but some methods use *n-grams* instead of actual words [71]. In this case, 5-grams are generated from every group of five consecutive letters. For instance the sentence "New York is large" results in the following 5-grams:

'new y', 'ew yo', 'w yor', ' york', 'york ', 'ork i', 'rk is', 'k is ', ' is l', 'is la', 's lar', ' larg', 'large'.

Different values of n could be used to generate different length terms. In this case, the choice of five is explained to include multiword phrases, such as 'New York' and short, important strings, such as abbreviations (NYC) in the final term vector. The benefits of using n-grams instead of regular words, that often require stemming, is that they are language independent, robust against misspellings and capture multiword phrases. [71]

After document indexing, the term-by-document matrix is generally very large, due to the large number of individual words in the document set. Furthermore, this matrix is usually very sparse, as not every word normally appears in every document. The result is a very large feature space that is neither useful or nor easy to compute for the classification algorithms. Due to this issue of high dimensionality that is problematic for most classification algorithms, dimensionality reduction is performed before final classification. Additionally, this reduction reduces the problem of *overfitting*, that occurs when a classifier is "tuned also the contingent characteristics of the training data rather than just the constitutive characteristics of the categories" [20]. This tends to produce classifiers that are very good at reclassifying the training set, but are very poor at correctly classifying any new data.

A distinction is made between two levels of dimensionality reduction: local and global. Basically, this is the decision of whether the process of feature selection is performed for the entire document set at once or for each category individually. Most dimensionality reduction techniques apply to both local and global reduction.

Furthermore, dimensionality can typically be reduced at two stages: before and after the indexing. Before indexing, words can be removed that clearly have no added information to the classification. After indexing, the calculated weights can be used as the basis for further removal of non-informative words.

Copyright © 2008 Capgemini – All rights reserved

Before creating the term vector, dimensionality can significantly be reduced by removing *stopwords* and performing *word-stemming*. Stopwords are "frequent words that carry no information," such as pronouns, prepositions and conjunctions [70]. Word stemming is "the process of suffix removal to generate word stems... to group words that have the same conceptual meaning, such as *walk, walker, walked, and walking*" [70]. A popular word stemming algorithm is the Porter Stemmer [72].

Feature selection is the process of choosing the most informative terms from the initial term vector and removing the least informative. There are several well-known methods for choosing the most informative terms from the initial term vector and removing the least informative. The first five methods are explained and thoroughly compared in [73].

The simplest methods are *document frequency thresholding* (DF). For this method, the number of documents in which a certain term occurs is used as the indication of the relevance of that term. A value is chosen as the threshold T and all words that occur in fewer documents than this threshold are removed. Due to its low computational complexity, that is near linear to the number of training documents, this method scales very well to large document sets. This technique is surprisingly effective and can "reduce the dimensionality of the term space by a factor of 10 with no loss in effectiveness (a reduction by a factor of 100 brings about just a small loss)" [19]. However, the guiding assumption that all low document frequency terms are non-informative seems to be counter-intuitive.

The *information gain* (IG) method measures "the number of bits of information obtained for category prediction by knowing the presence or absence of a term in a document" [73]. This is computed (see Appendix C) by first finding the fraction of documents that belong to a certain category and then finding the fraction $Pr(t)$ of those documents that contain the term t and the fraction $Pr(\bar{t})$ of those document that do not contain term t. This results in a number of bits of information, that reveal if this term is a discriminating feature of this category. The higher the number, the more discriminating. A threshold value can then be used to determine which features to remove and which to retain.

The *mutual information* (MI) method considers the interdependence of term t and category c. This is performed by counting the number of instances, A, in which they both occur, the number of instances, B, when t occurs without c and the number of instances, C, when c occurs without t. This process is shown in Appendix C, where N is the total number of documents. If t and c are independent of one another, the result will be zero; otherwise a positive value will indicate the level of mutual information. Unfortunately, this method is not robust against terms of widely differing frequency and should therefore be used only when a document set is specifically suited.

Another method to measure this interdependence is the χ^2 *statistic* (CHI). As above, A is the number of instances both t and c occur, B is the number of instances when t occurs without c, C is the number of instances when c occurs without t and N is the total number of documents. Furthermore, D is the number of instances neither c nor t occurs. As with the mutual information, this will result in a value of zero if t and c are independent of one another, otherwise a positive value will indicate the level of interdependence. This method is more robust against widely differing frequencies; however, not against very low frequencies.

Copyright © 2008 Capgemini – All rights reserved

Finally, *term strength* is a method that is "radically different from the ones mentioned earlier. It is based on document clustering, assuming that documents with many shared words are related, and that terms in the heavily overlapping area of related documents are relatively informative" [73]. First, pairs of closely related documents, x and y, are chosen, based on the cosine value of their term vectors. Then, the term strength $s(t)$ is computed as the probability that term t occurs in y, given that it occurs in x.

In addition to these formulas, there are even several more discussed in the literature, including DIA association factor, NGL coefficient, relevancy score, odds ratio and GSS coefficient [20].

The methods for dimensionality reduction introduced above are all forms of *feature selection*, as they attempt to extract relevant terms from the existing term vector. In contrast to this, *feature extraction* "attempts to generate... 'synthetic' terms that maximise effectiveness. The rationale for using synthetic (rather than naturally occurring) terms is that, due to the pervasive problems of polysemy, homonymy, and synonymy, the original terms may not be optimal dimensions for document content representation. Methods for term extraction try to solve these problems by creating artificial terms that do not suffer from them" [20]. Feature extraction is also referred to as re-parameterisation as it "is the process of constructing new features as combinations or transformations of the original features" [70]. Well researched methods for feature extraction include *term clustering* and *latent semantic indexing.*

Term clustering is the process of grouping words together that are closely related, so that these groups can be used in the instead of the original terms, thus reducing the number of terms in the final document vector. The basis of this close relationship is most often semantically motivated, thus synonymous or near synonymous words are grouped together. In other cases, similar usage patterns can be the basis of forming groups, such as the co-occurrence or co-absence in a document. However, according to a survey of published experiments [20], the clustering method has not yet proven to be very effective.

Latent Semantic Indexing (LSI) is probably the most promising of the feature extraction methods. This method was first introduced by [21] as a means of dealing with the typical document retrieval problems. Namely, that users wish to retrieve documents on the basis of conceptual content, rather than specific words. LSI assumes "there is some latent semantic structure in the data that is partially obscured by the randomness of word choice with respect to retrieval," and attempts to reveal this structure by treating word usage as a statistical problem [21].

LSI uses *singular value decomposition (SVD)* to compress the original "document vectors into vectors of a lower-dimensional space whose dimensions are obtained as combinations of the original dimensions by looking at their patterns of co-occurrence" [20]. SVD decomposes the original document-term matrix X into three matrices T_0, S_0, and D_0', such that the product of these is the original matrix. The first two columns of these matrices are then extracted to produce T, S, and D' which are multiplied together to produce an approximated version of the original matrix $\hat{X}$. After this reduction, the approximated version

Copyright © 2008 Capgemini – All rights reserved

of the matrix is not exactly identical to the original that allows for better classification of documents not in the training set. A more detailed example can be found in [21].

Due to the method of reduction, "words which occur in similar documents may be near each other in the [reduced matrix] even if they never co-occur in the same document. Moreover, documents that do not share any words with each other, may turn out to be similar" [70]. Research shows that the LSI approach correctly classified documents that the χ^2 approach did not, as relevant documents were found that did not contain the exact words from the query. An example of this can be seen below in Figure 4-3. In this example, the document text was correctly categorised, despite the document text and category description having no common terms.

> ***Category:*** *"Demographic shifts in the U.S. with economic impact"*
> ***Document text:*** *"The nation grew to 249.6 million people in the 1980s as more Americans left the industrial and agricultural heartlands for the South and West"*

Figure 4-3 Example of LSI classification [19].

However, this can also result in the loss of "some original term [that] is particularly good in itself at discriminating a category" [20]. An additional disadvantage is the time required to update the computation, if documents are added or subtracted from the collection; however, several methods have been proposed to make this task more efficient, such as *folding-in* and *SVD-updating* as discussed by [70]. A promising refinement of this method introduced by [74] is called *Probabilistic Latent Semantic Indexing*. This approach is based on the likelihood principle and shows significant improvement in precision over the original approach.

Finally, there is the step of classification. This is the process of using the term vectors created in the previous steps to determine the correct category assignment for each document. This also can be accomplished using several methods, of which the most well-known techniques are presented below. These methods can be roughly grouped into *profile-based classifiers*, and *example-based classifiers* [19].

Profile-based classifiers (also referred to as linear) generate a profile for each category, in the form of a weighted term vector that can then be compared to document term vectors to determine appropriate classification. Example-based classifiers compare each new document to the documents in the training set until finding a certain amount of most similar documents or "nearest neighbours."

Decision trees are built of nodes (tests) and leaves (decisions) that a document vector can be compared to in order to reach a classification decision. Decision tree classifiers are built in two phases: 1) a creation phase, where the initial rules are structured into the tree, and 2) a pruning phase, where branches are removed to avoid the problem of overfitting the tree to the training set [70].

The Rocchio classifier is considered a linear classifier [20]. First, a category profile is created by averaging the term vectors of the documents in the training set. Then the term vector for a new document is compared to each of the category profiles and the document is assigned to the category whose profile most closely matches. This classifier uses parameters

Copyright © 2008 Capgemini – All rights reserved

(β and γ) to tune the relative weight of both positive and negative examples. The formula commonly used for this approach to compute the strength of a feature in a document is shown in Appendix C.

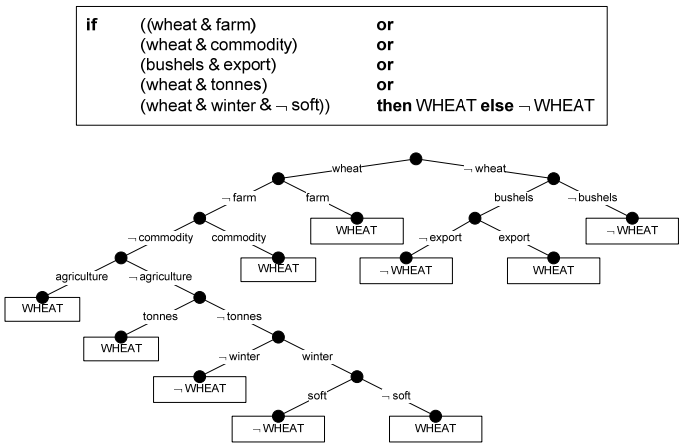

Figure 4-4 Example rule-based classifier and the derived decision tree [20].

In the document vector formula, *s(f,d)* is the strength of feature *f* in document *d*, *v(f,d)* is the relative relevance of multiple occurrences, *N* is the total number of documents, n_f is the subset containing feature *f* and n_k is the subset of containing feature *k*. In the class vector formula, *w(f,c)* is the weight of feature *f* in class *c*, D_c is the set of documents classified under *c* and $\overline{D}c$ is the set of non-*c* documents. Additionally, the parameters β and γ can be used to tune the formula by adjusting the relative importance of positive and negative training examples. As with most linear classifiers, this method divides the set in two based on the average of all positive examples, that can result in very poor accuracy as the average is only partly representative of the whole set [19].

The Naïve (or simple) Bayesian classifier is considered a probabilistic classifier, as it estimates the probability that a document d_j belongs to class c_i given the features present or not present in vector of the document [20]. The theorem proposed by Thomas Bayes, states that this probability is equivalent to the formula shown in Figure 4-5.

$$P(c_i|\vec{d}_j) = \frac{P(c_i)P(\vec{d}_j|c_i)}{P(\vec{d}_j)}$$

Figure 4-5 Bayesian classifier.

In this formula, $P(c_i)$ is the probability of a random document belonging to class c_i and $P(d_j)$ is the probability of vector d_j occurring. Assuming independence of attributes ($a_1, a_2, a_3,\ldots,a_n$) in vector d_j, this formula can be reduced to the form shown in Appendix C. A more detailed version of the formula from [19], also given in Appendix C, reveals the computational consideration if term *t* is present or absent from document d_j or class c_i.

The "naïve" element of this approach is the assumption that the probabilities of words occurring or not occurring are conditionally independent of one another: the *binary independence hypothesis*. In other words, the probability of a word occurring is neither increased nor decreased, if the presence of other words is known. However, these

Copyright © 2008 Capgemini – All rights reserved

“independence assumptions on which naïve Bayes classifiers are based almost never hold for natural data sets, and certainly not for textual data” [75]. For instance, consider the situation of a formal letter beginning with the words “to whom it may...”. The probability that the next word is “concern” is intuitively far greater than the probability that the next word is “hurricane” or “banana.” This probability could partially be calculated using grammatical rules, such as verb placement, as well as contextual thesauri, such as those mentioned in Chapter 2. However, this method ignores those interdependencies as “a matter of convenience, as both computing and making practical use of the stochastic dependence between terms is computationally hard” [19]. Despite this simple design, this classifier is surprisingly effective.

Naïve Bayes is typically known to be less accurate than most of the techniques discussed in this document, but its low complexity makes it attractive for systems where speed is preferred to precision. Furthermore, there are several proposals to improve this method by experimenting with the term selection stage [76,77]. As with most classifiers, term reduction can improve performance. However, in some cases it has been found to be “extremely counterproductive” [19]. The ability for this method to perform surprisingly well despite using the entire set of original terms can be advantageous in some situations, such as real time classification, where reducing time complexity is critical.

The *k*-Nearest Neighbour classifier is considered an example-based classifier, that means that the training document (examples) are used for comparison rather than an explicit category representation, such as the category vectors used by other classifiers. Thus, this method actually reuses the judgments made by the experts during the selection of the training documents to predict classification of new documents. As such, there is no real training phase. When a new document needs to be categorised, the *k* most similar documents (neighbours) are found and if a large enough proportion of them have been assigned to a certain category, the new document is also assigned to this category, otherwise not [19]. In this formula (see Appendix C), the *category status value* (CSV) is computed by summing up the *retrieval status value* (RSV) between document d and document $\bar{d}$ for all documents in the training set *TR*. The CSV is the value between 0 and 1, that represents the strength of the evidence that a document should be assigned to a particular category, and the RSV is the value that measures the level of relatedness or similarity between documents [19]. The value of ca_{iz} is 1 if regarded as a positive example and 0 or -1 if regarded as a negative example.

Support Vector Machines (SVM) represent one of the most advanced and promising classifiers to date. This approach can be understood by plotting all positive and negative examples in a multidimensional space and then finding the plane σ_i that separates positive from negative examples with the widest margin [20]. This is visualised in Figure 4-6. The “support vectors” are the set of parallel lines which are used to measure the margin of separation and thus indicate the best location for plane σ_i.

In experiments by [78,79] SVMs were the most accurate method of five different learning algorithms, including Naïve Bayes and decision trees. The SVM used achieved a maximum of 98.2% accuracy and an average of 87.0% accuracy, much higher than the other

Copyright © 2008 Capgemini – All rights reserved

methods tested. In experiments by [80] SVMs were again the most accurate method of five methods compared.

This approach integrates both dimension reduction, as well as classification, but is only applicable to binary decisions; therefore any multi-classification decisions must be restructured as a chain of binary decisions. Furthermore, it has been shown that SVMs can deal with large data sets by dividing the training set into subsets from which support vectors can be derived. These vectors can then be recombined from all subsets to produce a vector equivalent to that which would have been realised through global processing [70]. This allows SVMs to scale well without loss in effectiveness.

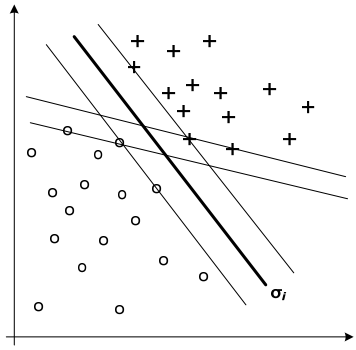

Figure 4-6 SVM classifier [20].

As previously stated, we are covering only a very few of the many possible classifiers. Other classifiers include those based on *neural networks*, such as *Perceptron* and *Winnow* [81]. This includes *positive winnow* and *balanced winnow,* all of which use the method of mistake-driven learning to update a weight vector of active features.

Much research has also been performed on the effectiveness of combining classifiers to achieve higher accuracy. The idea is that most classifiers only accurately classify a subset of the documents. By applying multiple classifiers, each targeted at a different subset of the documents, the entire set will be classified accurately. This can be performed in the form of having an odd number of classifiers in a *committee* classify the same documents and then take the majority vote of the appropriate classification. Experiments have been performed by [82] using this technique for spam email classification. These experiments combined one Naïve Bayes and two *k*-NN classifiers to produce better results than using any of the classifiers independently.

Another successful method of combining classifiers is called *boosting*, as embodied by the AdaBoost algorithm [83], that "combines many weak, moderately accurate classifiers into a highly accurate ensemble". This involves tuning certain variables to create multiple versions of the same classifier, that when used together can accurately classify all documents in the training set.

Hybrid classifiers are another form of combining classifiers to reach higher effectiveness. This can be a combination of both intrinsic metadata, such as the results of statistical analysis by one of the classifiers described above, as well as extrinsic metadata, such as the age, author or location of a document. A field where these approaches have been

Copyright © 2008 Capgemini – All rights reserved

massively researched and successfully implemented is that of spam email classification (filtering).

An example of a successful hybrid classifier is the open source spam filter *SpamAssassin* [84]. This combines rule-based classification with a Bayesian classifier. This filter uses multiple checks to determine if an e-mail message belongs to one of two categories: 1) unsolicited (or spam), or 2) normal (non-spam or *ham*). This is similar to other binary document classification systems, where documents are classified as either relevant or non-relevant for a given query. SpamAssassin applies feature weighting by testing multiple rules on each message and assigning points to measure the likelihood that the message is spam, given the outcome of the applied rule. This includes checks on the content of the message, the metadata included with the message and information found about the sender (server) of the message.

An example of the spam report, including the rules applied and the point assigned is shown below in Figure 4-7. These rules can include:

- Keyword checks for suspicious phrases, such as “MAKE MONEY FAST” or “CLICK BELOW”
- Message content and layout checks, such as hidden HTML or images without text
- Metadata checks, such as checking the address of the sending server against an online list of known open relay servers (also called real-time blackhole lists, or RBLs)
- Whitelist/blacklist checking against user-provided addresses
- Bayesian classifier checks, that are trained on user-provided examples of spam and non-spam e-mails
- 750 additional pre-built rules and any user-built rules.

```
Return-Path: <chronograph@brainpod.com>
X-Spam-Flag: YES
X-Spam-Checker-Version: SpamAssassin 3.2.4 (2008-01-01) on MAILSERVER
X-Spam-Level: ********
X-Spam-Status: Yes, score=8.5 required=5.0 tests=BAYES_50,DNS_FROM_RFC_DSN,
HTML_MESSAGE,MIME_HTML_ONLY,RCVD_IN_PBL,RDNS_NONE,URIBL_BLACK,URIBL_OB_SURBL,
URIBL_RHS_DOB autolearn=no version=3.2.4
X-Spam-Report:
*  0.9 RCVD_IN_PBL RBL: Received via a relay in Spamhaus PBL
*      [189.71.152.42 listed in zen.spamhaus.org]
*  1.5 DNS_FROM_RFC_DSN RBL: Envelope sender in dsn.rfc-ignorant.org
*  1.1 URIBL_RHS_DOB Contains an URI of a new domain (Day Old Bread)
*      [URIs: yourlifegaming.net]
*  1.5 URIBL_OB_SURBL Contains an URL listed in the OB SURBL blocklist
*      [URIs: yourlifegaming.net]
*  0.0 HTML_MESSAGE BODY: HTML included in message
*  0.0 BAYES_50 BODY: Bayesian spam probability is 40 to 60%
*      [score: 0.5000]
*  1.5 MIME_HTML_ONLY BODY: Message only has text/html MIME parts
*  2.0 URIBL_BLACK Contains an URL listed in the URIBL blacklist
*      [URIs: yourlifegaming.net]
*  0.1 RDNS_NONE Delivered to trusted network by a host with no rDNS
```

Figure 4-7 Example headers of e-mail tagged by SpamAssassin.

The strength of a hybrid classifier is that it can accurately classify a document, even if one or more of its classification mechanisms fails to do the same. For instance, in the example, the message was accurately classified as spam, despite having failed the Bayesian classifier check. As discussed earlier, Bayesian classifiers are very efficient, but not as accurate as

Copyright © 2008 Capgemini – All rights reserved

other classifiers. Research shows that other classifiers [85] or other extensions to Bayesian classification [86] can improve the accuracy of spam classification. This research is based on the novel concept that spam classification is a form of authorship attribution and the results are very promising.

Ultimately, classifiers are evaluated in terms of complexity and effectiveness. Complexity can be seen in terms of time, memory and computational requirements, whereas effectiveness can be measured by *precision* and *recall*. The notion of precision and recall are very similar to those of soundness and completeness of logical systems. Precision is the probability that if a random document is classified under a certain category, this decision is correct. Recall is the probability that if a random document should be classified under a certain category, this decision is taken. Together, these measurements can be used to determine accuracy, error and fallout. This can be visualised by the formulas shown in Table 4-5 [70]. In these formulas, the following variables are used:

- a – the number of documents *correctly assigned* to this category
- b – the number of documents *incorrectly assigned* to this category
- c – the number of documents *incorrectly rejected* from this category
- d – the number of documents *correctly rejected* from this category

Recall	$\frac{a}{a+c}$
Precision	$\frac{a}{a+b}$
Fallout	$\frac{b}{b+d}$
Accuracy	$\frac{a+d}{a+b+c+d}$
Error	$\frac{b+c}{a+b+c+d}$

Table 4-5 Performance measures of classifiers [70].

Extensive comparisons have been made by researchers between the different classifiers on different training and test sets [87-91,71,73,78,80]. A general consensus is that the latest SVMs are the most accurate classifiers. However, new combinations and extensions of other classifiers can provide even better results. These have been mainly concerned with the measurements listed above, namely false positives and false negatives. However, these comparisons have been less concerned with practical differences, such as time, memory and computational requirements.

As we have seen, there are many possible techniques for document classification, ranging in complexity and effectiveness. This is an area of growing interest and continuing research will surely lead to better classifiers either as combinations of existing techniques or perhaps entirely new approaches. Despite substantial research into new methods and revisions of older methods [20] concludes that: 1) automated text categorisation has reached effectiveness levels comparable to those of trained professionals, and 2) levels of

Copyright © 2008 Capgemini – All rights reserved

effectiveness of automated text categorisation are growing at a steady pace. Though it is doubtful if these levels will ever reach 100% as not even manual classification can reach this level.

The most useful implementation of these classifiers will most likely be by using multiple classifiers in both committee and hybrid fashion. The benefits of these approaches are shown above with the example of spam classification. By combining classifiers that take multiple factors into account, higher accuracy can be achieved than by a single classifier alone. For instance, taking both intrinsic (content) and extrinsic (author, age, size) metadata into consideration by combining:

- a latent semantic indexer to capture unapparent patterns and relationships,
- a committee of highly-accurate SVM classifiers tuned using the boosting technique to classify documents based on previous examples, thus identifying document subjects or types,
- and a rule based classifier, perhaps in the form of a decision tree to evaluate both keywords of the contents, such as known names or numbers, as well as extrinsic metadata describing the document.

Depending on the ultimate implementation of an automated security classifier, there will be different requirements as to false positives, false negatives and efficiency. By combining the best features of multiple classifiers, it will be possible to produce systems that provide one of these features, albeit at the expense of the others. In a binary classification scheme, this could mean the design of a system that can guarantee that no confidential documents will be classified as public, but would tolerate a certain level of public documents classified as confidential. Again, this reflects the eternal trade-off between security and usability.

4.4. CONCLUSION

This chapter has discussed the requirements and technologies of classification. To derive the requirements, we investigated the security classification decision factors of both government and private sources. This allowed us to identify the elements that must be extracted from the documents and stored to perform this decision. We also discussed current classification technologies, such as simple parsing and advanced statistical analysis methods. In addition to introducing these techniques, we also identified several ways to increase the accuracy by combining classifiers. According to our research, the best of these techniques include hybrid classifiers to classify different parts of documents and classifier committees to combine different types of classifiers. In addition, we proposed strategies to improve the applicability of such classifiers in our context, such as guaranteeing no false negatives, at the cost of more false positives.

Copyright © 2008 Capgemini – All rights reserved

5. MODEL FOR AUTOMATED SECURITY CLASSIFICATION

In this chapter, we will propose a model for automated security classification of documents to address some of the issues covered in Chapter 3, and using the requirements and technologies covered in Chapter 4. We will begin by giving an overview of the complete model, then proceed to describe each component in detail, using the information covered. Finally, we will suggest several applications of the model to illustrate different possible uses of this generic model.

5.1. OVERVIEW OF THE MODEL

This model represents the concept of a generic, Automated Security Classification (ASC) system. Basically, this model takes a file as input and, after several automated decisions, assigns an appropriate security classification to that file. The grey shading encompasses the components that will be the focus of this research.

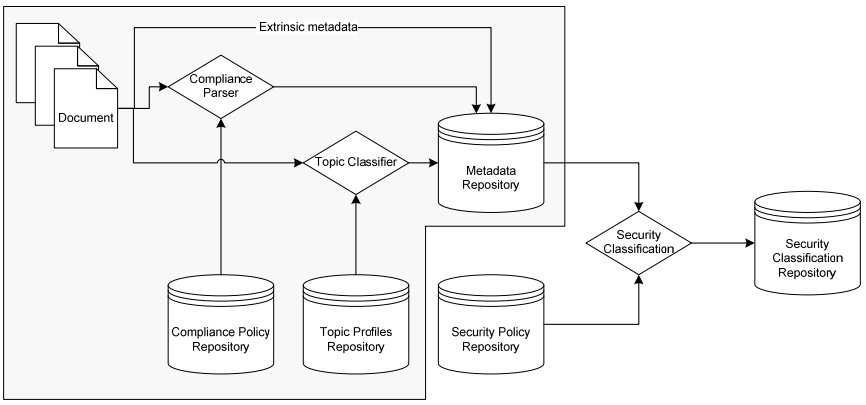

Figure 5-1 Generic model of automated security classification (ASC).

Document — Document containing mainly text (rapport, e-mail, etc.) has *extrinsic metadata*, such as name, author, date created, date modified, size, location, delivery path, etc., and *intrinsic metadata* that appear in the file contents, such as the subject, title, names of people mentioned, etc.

Compliance Policy Repository — Stores rules regarding personal privacy issues in compliance with government regulation or company policy. (e.g. personally identifiable information, etc.)

Compliance Parser — Parses contents of documents, searching for objects that conflict with the compliance policy. (e.g. credit card information, social security number)

Topic Profiles Repository — Stores profiles for each of the pre-defined document categories. Is created automatically by a machine learning process.

Topic Classifier — Reads contents of document, extracts features and performs statistical analysis, such as Latent Semantic Indexing, Bayesian classification, etc. in order to determine document topic(s). Compares document profile with

Copyright © 2008 Capgemini – All rights reserved

	topic profiles stored in Topic Profile Repository to determine appropriate classification. Stores topic classification in Metadata Repository.
Metadata Repository	Stores output from Topic Classifier module. Can be stored in separate database or in document headers. Contents include intrinsic metadata from documents and extrinsic metadata resulting from content analysis.
Security Policy Repository	Stores rules regarding company security policy used in the Security Classification decision process. Such rules can include classifications based on subjects, departments, authors, age or location (e.g. project X is Top-Secret, author X is unclassified, project X is unclassified if age > 10 years, etc.).
Security Classification	Reads from Metadata and Business Rule repositories. Makes security classification decision based on these inputs. Assigns a security classification to file and stores in Security Classification Repository. Security Classification based on chosen security model (e.g. top-secret, secret, etc.).
Security Classification Repository	Stores security classification of files, as given by Security Classification module. Can be stored in separate database or in file headers. Contents include security classification based on chosen security model (e.g. document X is Top-Secret, etc.).

5.2. Components of the Model

The model shown in Figure 5-1 identifies seven components required to perform the initial stage of automated security classification, namely to build the metadata repository. These components are: 1) documents; 2) extrinsic metadata; 3) compliance parser; 4) compliance policy repository; 5) topic classifier; 6) topic profiles repository, and 7) the metadata repository.

The document component is the input of the model. In this context, we are referring to unstructured or semi-structured text files, such as emails or other text documents. This does not refer to images or video files that are not handled by this model and are thus not covered by this research. This unstructured, textual data represents the bulk of relevant corporate information [4]. These files come in many different formats, such as unstructured word processor files, e-mails, memos, notes, letters, surveys, white papers, presentations, and so on, or semi-structured files, such as spreadsheets. Additionally, some of these semi-structured files follow some general standard, such as containing additional metadata containing date of creation, modification, last access, or name of the author. Furthermore, no assumptions are being made about the locations of these documents. This could be on a local hard drive, network share, or a central file server. The only hard requirement is that the content of the file is accessible, thus encrypted files or password protected files cannot be processed.

This extrinsic metadata has already been touch upon in the form of semi-structured metadata concerning date of creation, modification, last access or name of the author. This is

Copyright © 2008 Capgemini – All rights reserved

considered extrinsic, as it is not part of the content of the file, and therefore not required for the file to function or the meaning to be intact. In addition to the metadata listed, this could include the location (file path) and size of the document, the group (department or role) of the author, or format specific information as in the case of additional metadata included in an email, such as the address of the sending server. This data can be used if present, but should not be assumed to be available for every file and therefore should not be relied solely upon.

The compliance parser is a search agent using techniques discussed in Chapter 4 that is targeted at specific words, numbers or other patterns that could constitute regulated information, such as protected PII or PCI details. The privacy parser does not do any advanced statistical analysis, and thus will remain very cheap in terms of complexity and computational requirements. Examples of some terms that would be found by this parser would be numbers in the format of a credit card or social security number, or terms deemed suspicious. Additional checks are also possible to discern sensitive numbers from non-sensitive numbers, such as the Luhn algorithm for validating credit card numbers [69]. In addition to single term search, this parser could add weights depending on which multiple terms are found in the same document. For instance, a document containing a social security number (SSN), as well as a list of medications should be more likely a breach of compliance policy than a document containing only the list of medications. Similarly, in the case of PCI compliance, a document containing only one element of the magnetic strip is less sensitive than a document that contains multiple elements. The depth and scope of its search will be defined by the compliance policy repository component.

The compliance policy repository will contain the rules to be applied by the compliance parser. These policies will be influenced by the factors discussed in Chapter 3. This can include predefined dictionaries of words or patterns common to regulated information, such as credit card or personal information. This will also store relative weights for individual terms or in the case that multiple terms are found that could constitute a breach of compliance policy. For instance, a document containing multiple privacy terms is more suspicious than a document containing only one term. In fact, in the case of PCI compliance, a document containing the full contents of the magnetic strip is an immediate violation, whereas containing only one element is not. The formulas for computing these weights could in turn be developed using machine learning techniques as described in Chapter 4. These formulas could determine the relative likelihood that a document containing one term or another is necessarily a breach of compliance policy. Once the document has been parsed, the compliance policy repository would pass on its rating of the documents sensitivity to the metadata repository. This could be achieved by providing a full list of all sensitive terms found along with their respective weights, or just a final rating, such as the final likelihood product of all terms found. This repository does not need to store any information from documents being processed; however, it will be possible to update and fine tune the formulas and terms stored there by a separate process, either manually or using machine learning techniques discussed earlier.

Topic classification will be performed on the content of the document, ignoring all extrinsic metadata. This will be performed to establish a document topic or type. For

Copyright © 2008 Capgemini – All rights reserved

instance, this will determine if a document is an annual financial report or discusses a certain project. To perform this classification, a document profile will be computed and compared to profiles stored in the topic profiles repository component. This operation will be more costly than the compliance parser, in terms of computational requirements, but this design requires that only the document profile be computed and compared to the pre-computed profiles stored in the repository. This design minimises the re-computation of existing profiles to achieve maximum efficiency.

The topic profiles repository will store pre-computed profiles identifying the various document types and topics present in the corporate network. Building this repository will be the most computationally expensive part of the classification model. This will require a clear taxonomy of all document types and topics to be manually created by domain experts. Each of the categories in the taxonomy must be described with examples, at this point. The amount of examples required is different for each classifier, but in general, more is better. These examples will then be used to compute the topic profile for each category in the taxonomy. This must be performed offline, meaning that it is crucial that these profiles are computed prior to classifying documents.

In technical terms, the accuracy of this component is much more important than the efficiency. As this component is separate from the model and can be computed offline, the model is thus designed to maximise efficiency of document classification by separating components such that accuracy and efficiency are not at the expense of each other. Due to this feature, this component can use the most accurate methods of classification, such as combining SVMs into a classifier committee as described in Chapter 4.

The metadata repository is the most crucial part of the ASC model. If this repository is properly constructed to contain all relevant information, then subsequent security classification decisions can be made appropriately. However, if the metadata provided is inaccurate or insufficient, any subsequent security classification will also be flawed. Based on the identified security decision factors discussed earlier, we propose that the metadata repository should contain the information contained below. First, we will present this in Table 5-1 as an overview and template of an entry in the repository. We will then proceed to describe this in further detail.

Title	Value / Format	Com.	Example
Date of Creation	DD/MM/YYYY/HH:MM:SS	E	24/06/1980/06:00:00
Data Owner/Author	text	E	Domain/user
Original Classification	text or number	E	Secret, 3, SEC
Compliance Violation*	Text and number (degree 0-9)	C	PII:5, SPI:0, PCI:0, ETH:2
Category / Topic*	Text and number (certainty 0-9)	T	Financial Statement:9, Application:0
Document location	Text	E	\\Server\shares\userfiles\
Last access	DD/MM/YYY/HH:MM:SS	E	07/07/2000/08:08:00
Last modification	DD/MM/YYY/HH:MM:SS	E	04/12/1990/22:14:03

Table 5-1 Format of metadata repository.

Table 5-1 shows the title of the metadata element, the value and format of the entry, the component of the model by which it was provided (E = Extrinsic metadata, C = Compliance parser, T = Topic classifier), and finally, an example of an entry. Titles marked with (*) must support multiple instances, bound by a finite set determined by the taxonomy.

Copyright © 2008 Capgemini – All rights reserved

Date of creation – The date of creation remains an important part in determining the duration of classification and retention of a document. This value can be used to calculate the date of reclassification or declassification, based on security policies. This is supplied by the extrinsic metadata of the document.

Data Owner/Author – The data owner remains an essential part of the security classification. In most cases, this is the person with the most intimate knowledge of the document and direct responsibility for maintaining an appropriate security classification and subsequent protections. Knowledge of this the role or rank of an individual in an organisation can further be used to calculate likelihood of producing certain types and classifications of information, such as might define a role-based classification policy. This is supplied by the extrinsic metadata of the document.

Original classification – In the case that an original classification is provided, this should be preserved in the metadata repository, as it could be still required by security policy. Security policies could further be defined to compare this classification (if any) to the classification calculated on the basis of the other factors and take special steps if the two levels are different, such as always applying the higher of the two. This is supplied by the extrinsic metadata of the document.

Compliance violation – This element will contain the type and degree of a possible compliance violation. As multiple violations are possible, this element must support multiple instances, that are limited by a finite set as determined by the taxonomy stored in the compliance repository. This is supplied by the compliance parser.

Category / Topic – This element will contain the category or topic of a document, as well as the level of certainty of that categorisation. As multiple topics are possible for one document, this element must support multiple instances, that are limited by a finite set as determined by the taxonomy stored in the topic profiles repository. This is supplied by the topic classifier.

Document location – This element will contain the location of a document, in the form of a file path. This information can be used to determine if certain polices are being violated with regard to certain classifications being stored in high risk locations. For instance, PCIDSS [44] requires that certain information is not stored together at one location. Also, a certain corporation might require all intellectual property information to be stored on a certain central server and not on a workstation.

Last access – This element will establish the date the file was last accessed. While this information might not be relevant for most security classification decisions, it can be useful for other applications, such as auditing or archiving. This is supplied by the extrinsic metadata of the document.

Last modification – This element will establish the date the file was last modified. While this information might not be relevant for most security classification decisions, it can be useful for other applications, such as auditing or archiving. This is supplied by the extrinsic metadata of the document.

Copyright © 2008 Capgemini – All rights reserved

5.3. APPLICATIONS OF THE MODEL

We will now introduce specific applications of the generic ASC model introduced in this chapter to examine the abilities and limitations of this proposition. These will be organised in the following way. First, we will introduce the application, as it would fit into a corporate setting. Then we will walk through a use case of this application. Finally, we will evaluate the application in terms of effectiveness, usability and limitations.

Three applications of the ASC model will be discussed in this section, including 1) Audit Tool; 2) Safe Storage, and 3) Data Leakage Prevention (DLP). There are general steps that are common to all applications of the model and thus are listed before the specific steps of each application. These steps can occur offline and outside of office hours to minimise negative impact to user experience and business operations. These steps include 1) creating document taxonomies; 2) providing training documents; 3) training and building the profiles, and 4) subsequent steps.

The first step in any classification task is to create document taxonomies to provide detailed map of all document types in an organisation. According to Sanja Holtzer (see Appendix A) of Capgemini, who has been involved with similar classification projects, this step is often the most difficult and manually intensive step, that usually requires the collaboration of end users, managers and knowledge engineers. Document taxonomies will be required by the Compliance Policy, Topic Profiles and Security Policy Repositories. A choice can be made if separate versions are required for each of these repositories, but in most cases a single taxonomy, if complete and detailed enough, will be sufficient for all three repositories. A simplified taxonomy is presented in Figure 5-2 to give the reader a general idea of what is required. A detailed example of such a taxonomy is presented by [92] along with a document formatting standard to simplify the generation of taxonomies. The more detail provided by a taxonomy, the more precise the following classification decisions can be.

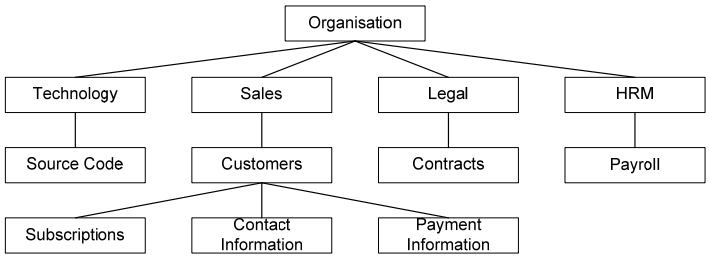

Figure 5-2 Example of document taxonomy.

The second step is to provide a set of training documents for each of the leaves of the taxonomy to provide examples to build each category profile. The exact number of these training documents is not specified in the classification literature, but can be dependent on the classifier used. The selection of these documents is also an area of contention. On the one hand, perfect examples are useful to represent a category; however, blind selection can also reveal useful distinguishing features that go otherwise unnoticed.

The third general step is to train and build the profile repositories. Building the Compliance Repository will be largely a manual process as experts are required to create the rules that constitute a compliance violation. This can be assisted by automated classification technology

Copyright © 2008 Capgemini – All rights reserved

to determine the respective weights (severity) of certain violations, but this is not essential to a functional repository. In contrast, building the Topic Profiles Repository will be performed almost entirely using the automated classification technologies discussed in Chapter 4. This will require the largest cost of time and processing, using the training documents as input to produce profiles for each of the leaves in the document taxonomy.

Subsequent steps, not covered by this research, will involve building the Security Policy Repository to contain all rules regarding to security violations. Then, after the Metadata Repository has been filled, entries can be taken from it and compared to the rules stored in the Security Policy Repository. The resulting security classification can then be stored in the Security Classification Repository and used as the basis of assigning security measures.

The first application is the Audit Tool. Corporations can use internal or external audits to ensure that no security policies are being violated. This can be utilised to conform to external certification or governmental decree as described earlier. Performing this audit internal and on a regular interval can prevent policy violations and the extra costs of external audits. Policy violations are, of course, dependent on the specific policies followed by a company, but examples could include a sensitive document being stored at a high risk location or being stored unencrypted.

The steps of the Audit Tool include 1) general steps; 2) locating input documents; 3) processing documents and building metadata repository, and 4) subsequent steps. The general steps are listed above in more detail. These include creating document taxonomies, providing training documents and, finally, training and building the repositories. The second step will be scanning the corporate network to find all documents that need to be evaluated by that ASC model. This will involve scanning all network shares, file servers and user workstations. This could also involve involving users to allow scanning of external USB storage devices, such as backup drives and PDAs. The third step will be to begin processing the documents found during the previous step, extracting their extrinsic metadata, identifying any compliance violations, identifying their appropriate topic (or category) and storing this information in the metadata repository. Subsequent steps, not covered by this research, are discussed in more detail above. These will involve performing the security classification and to determine if highly sensitive information is stored at insecure (uncertified) locations, such as a workstation or a public network share, or in an insecure (unencrypted) format.

One of the main trade-offs of the classification discussed earlier was between accuracy of classification and the higher cost of producing this, in terms of memory, time and processing requirements. This trade-off could be set in a different light, were this model implemented in a way that would minimise the negative effects of these additional costs. For instance, this application of an offline auditing tool could compute the topic profiles, scan all file shares, servers and user workstations for documents, perform the metadata extraction (extrinsic, compliance and topic components) and allow the security classification module to complete the classification. All of this could be performed offline, outside of working hours with minimal impact on user experience and business operations. In this case, all components of the model, except for input documents, could be centrally located on one logical server.

Copyright © 2008 Capgemini – All rights reserved

Network communication is only required for scanning the input documents; that would require relatively high network communication costs, but would centralise all processing to one logical server, thus making the system relatively transparent to other users and processes.

This application only accounts for a snapshot of the network and does not offer any scanning for documents as they are created or changed, once the audit has been performed. This allows the company to determine when to dedicate resources to this process and when to forgo this for other priorities. It must be noted that the assurance level reached by this audit concerning presence or lack of policy violations decreases as the number of new documents created since the last audit increases.

This application was favoured by several interviewees (see Appendix A) for several reasons. First, it was felt that sensitive information requiring strict controls only represented a small percentage of all corporate information (approximately 10%). Therefore, a one-time audit could find and identify this 10% at a minimal cost and impact to business operations. This application also fit an understood model for auditing and could be performed with minimal changes to the corporate infrastructure. For instance, this application was similar to a project undertaken at Eli Lilly called "Clean & Secure," during which the network was scanned and policy violations were identified. Furthermore, this application would not affect the end users and would thus avoid additional resistance or distraction.

The second application is Safe Storage. The confidentiality requirement of most classification schemes can be provided to a certain degree with the use of encryption to render documents inaccessible to unauthorised users. In the context of de-perimeterisation discussed in Chapter 2, proper application of encryption can protect data, independent of the underlying infrastructure and environment. In fact, the objective of this research is to find a mechanism for mapping documents to security measures, such as encryption. This application of the model attempts to perform this mapping in real time at the point of document creation.

Safe Storage is the calculation of the sensitivity of a document at the time of creation or modification and the application, at that point, of encryption to ensure the confidentiality of a document is preserved when stored, independent of the location of the document. This will involve a local agent performing the document scanning and communicating with a remote server providing the Compliance Policy, Topic Profiles and Metadata repositories across the corporate network.

The steps of Safe Storage include, 1) general steps; 2) new file creation; 3) document processing, and 4) subsequent steps. The general steps are listed above in more detail. These include creating document taxonomies, providing training documents and, finally, training and building the repositories. The second step occurs when a user creates a new file, such as a text document in Word format. The user enters text and saves the document. The third step involves the new document being processed by a local ASC agent in communication with remote repositories. This involves applying the Compliance Parser, Topic Classifier and extracting extrinsic metadata from the document. The extrinsic metadata is sent directly to the Metadata Repository. The Compliance Parser first compares its findings with the Compliance Policy Repository and sends the results to the Metadata Repository. The Topic Classifier then

Copyright © 2008 Capgemini – All rights reserved

computes the document profile and compares this to those stored at the Topic Profiles Repository and sends the resulting classification to the Metadata Repository. Subsequent steps, not covered by this research, will involve the local ASC agent then requesting a security classification decision based on the new entry in the Metadata Repository. As a result of this decision, encryption could be applied to the document stored on the workstation or the user could be advised to move the document to a secured file server or enter the document into a file management system with appropriate security safeguards.

In contrast to the previous application, the Safe Storage application involves constant, dynamic monitoring, rather than the single-use auditing approach. This will require more processing power as documents are created and modified often, but assurance levels that sensitive documents are being properly protected will remain higher than the static audit application approach. As the processing task of this application is distributed, this might improve the overall performance of the scanning task; however, users will be more affected by this approach as it occurs during office hours, in fact, directly involved with their work. Any final implementation of this application must consider and attempt to minimise any substantial delay or interruption to the normal tasks of a user. Network traffic will be relatively low as only the extracted metadata and document profile are sent across the network instead of the entire document.

This application was met with apprehension by nearly all interviewees (see Appendix A) for several reasons. First, it was globally doubted if the classification technology could be trusted to maintain a high consistency of highly accurate decisions. This could only be partially solved with a Proof of Concept in the form of a real world experiment. Furthermore, it was not felt that document level classification is actually necessary, despite the move towards de-perimeterisation. Most current classification schemes discussed earlier use a top-down approach to identify business processes that need such protections and then classify all applications, components and data that is processed or created by those processes. Clearly, the business case could not yet be made to adopt such an application if the benefits cannot outweigh the cost to the corporation and end users.

The final application is Data Leakage Prevention (DLP). This approach is slightly different to Safe Storage. DLP delays the scanning, classification and security mechanism until the document is leaving the protected environment of the user. As such, not all documents are processed by the model, but rather only documents that are crossing the perimeter. Examples of this perimeter crossing could be a document attached to an email, a document backed up to an external drive, such as a USB stick or PDA, a document uploaded over the network, or a document sent via an instant messaging service. These events would then trigger a local ASC agent to perform the scanning process in much the same fashion as described above for the Safe Storage application. In some cases, this can be referred to as an ‘information firewall’ that scans and optionally blocks sensitive information sent between two networks, such as between two departments in one organisation, between two collaborating organisations or between an organisation and the Internet.

The steps of DLP include, 1) general steps; 2) perimeter crossing; 3) document processing, and 4) subsequent steps. The general steps are listed above in more detail. These

Copyright © 2008 Capgemini – All rights reserved

include creating document taxonomies, providing training documents and, finally, training and building the repositories. The second step of this application involves a user attempts to move an existing file across the perimeter. This could be a standard email message, a text document attached to an email, or other any document leaving the workstation and protected environment, such as across the network or USB port. The third step occurs when the document is temporarily blocked and processed by a local ASC agent in communication with remote repositories. This involves applying the Compliance Parser, Topic Classifier and extracting extrinsic metadata from the document. The extrinsic metadata is sent directly to the Metadata Repository. The Compliance Parser first compares its findings with the Compliance Policy Repository and sends the results to the Metadata Repository. The Topic Classifier then computes the document profile and compares this to those stored at the Topic Profiles Repository and sends the results to the Metadata Repository. Subsequent steps, not covered by this research, again involves the local ASC agent then requesting a security classification decision based on the new entry in the Metadata Repository. As a result of this decision, the document could be prevented from crossing the perimeter or could first be encrypted, after notifying the user of the possible policy violation. A mechanism could also be left in place to circumvent these protections, if the user provides some extra explanation, thus implying understanding and intent to continue with these actions.

Of the applications listed in this chapter, the Data Leakage Prevention application would require the least resources, and thus, have the least impact on normal business operations. Only a subset of documents is processed, thus requiring less processing and network communications. However, the user will be directly affected if a possible policy violation is detected, that can result in an inability to perform the intended task or at least an additional action to imply understanding and consent.

As the DLP application will have the least impact on normal business operations, it will most likely be the easiest to implement. It should be noted, however, that this application does not provide assurance that policy violations do not exist, but rather that only these violations will not leave the protected environment. In other words, the only security policies that can be enforced are those that deal with exposure to the outside world.

According to several interviewees (see Appendix A), this application would be the least onerous. Due to recent experiences that involved confidentiality breaches, Adrian Seccombe (see Appendix A) could see how these might have been prevented with a filtering agent on the perimeter, specifically preventing emails containing privacy policy violations from being sent, without a warning to the user at the very least. Furthermore, due to the fact that this application could be implemented in such a way as to involve the user in the decision to block or permit a perimeter crossing, there was less reliance on the classification technology and more on the users, that can be trained to be more understanding of security requirements. However, as with the increase in the use of encryption after Safe Harbour legislation [93] that limited the liability of a company if they could show they had sufficiently tried to prevent the data leakage, it was suggested that such perimeter scanning and filtering applications would only be massively implemented upon similar government legislation.

Copyright © 2008 Capgemini – All rights reserved

5.4. CONCLUSION

This chapter introduced a new generic model of automated security classification of text documents. We gave an overview of the ASC model, including the elements required and their relationships with each other. We have seen how relevant metadata can be extracted from unstructured text documents using the techniques introduced earlier. Furthermore, we have shown how this extracted metadata can provide the basis for a subsequent security classification decision. We have also shown how the generic ASC model can be put to use for specific applications, such as the Audit Tool, Safe Storage or Data Leakage Prevention. We have identified the abilities and limits of these approaches, according to our own analysis, as well as that of several security professionals.

Copyright © 2008 Capgemini – All rights reserved

6. CONCLUSION

This chapter will conclude our research. We will return to our initial questions and give a summary of our findings. We will then list the issues that still must be addressed and propose possibilities for future research in this field, based on personal reflection and professional advice.

6.1. SUMMARY OF MOTIVATION

As stated in Chapter 1, this thesis deals with the area of electronic data protection. We introduced the growing importance of data protection, due to the increasingly complex obligation to comply with government regulation, protect corporate reputation and maintain competitive advantage. This was further motivated by the quickly growing and largely unstructured nature of corporate data. We also discussed the trend of "de-perimeterisation" and how this implies a "data-centric" approach to the problem that involves data protection measures that are independent of the underlying infrastructure.

We also acknowledged that many security measures already exist, such as encryption technologies, thus the problem is not *how* we can protect the data, but rather knowing *what* data needs to be protected. Not all data is equally sensitive and, thus, warrants the same level of protection. Therefore, these measures must be applied specifically and appropriately, based on the sensitivity of the individual data.

We also described the significance of classification as the first step towards applying such protections. This involves first indentifying and labelling sensitive data. However, several shortcomings were shown with the current, manual approach to classification, specifically with speed and consistency. This led us to introduce the automated classification techniques used for other purposes and propose their application to the problem of data protection. The objective of this thesis was to gain understanding of these possibilities, through the design of a generic model of automated security classification that would allow us to evaluate the feasibility of this proposition.

6.2. SUMMARY OF RESEARCH

The goal of this research was to determine if the process of building the metadata repository used for security classification can be fully, or even partially automated using techniques developed for other data classification systems, such as statistical or semantic analysis of unstructured text.

In addition to our main goal, we established several sub-challenges:

- determining the relevant metadata that must be stored in the repository;
- determining what relevant information is provided by the documents that must be classified, including their contents and extrinsic metadata, and
- evaluating current techniques for automated categorisation of unstructured text.

As this dissertation has shown, there are many promising techniques for automated document classification and research in those fields will most likely produce even better classifiers, in

Copyright © 2008 Capgemini – All rights reserved

terms of efficiency and accuracy. We have also seen that several techniques are available, such as hybrid classification that can be used to combine the strongest features of multiple classifiers to ensure the highest level of accuracy. Furthermore, we have seen that the metadata extracted and stored in the Metadata Repository can provide sufficient information as to be used for subsequent security classification.

Chapter 3 discussed the main concerns of data protection, specifically compliance to policies, both from government and the private sector. These alluded to the requirements of the Compliance Parser component of the ASC model that must be able to identify certain elements which could constitute Personally Identifiable Information (PII) or other sensitive elements. There are several techniques for parsing sensitive elements in unstructured text, such as keyword, regular expression or pattern matching. Additionally, some linguistic analysis can be performed to identify proper nouns and mathematical algorithms can be used to discern some sensitive sequences of numbers.

In Chapter 4, we explored the relevant factors of a security decision, using guidelines from both government, as well as private sector sources. Using these guidelines, we established the requirements of the Metadata Repository. Chapter 4 also covered the various steps and methods of automated document classification, including the various strengths and weaknesses of each of the main classifiers. We also discussed how these classifiers can be combined in committees and hybrid classifiers to increase accuracy.

While researching the various automated classification techniques also discussed in Chapter 4, it was learned that the most important part of a document required for these classification techniques is the content. Other attributes, such as extrinsic metadata, are only relevant for hybrid classifiers that need additional metadata to determine relationships and context. In the context of security classification, additional metadata is required only to establish the duration of classification, not to establish the classification itself. However, in the case that additional consideration is paid to documents created by certain authors, with regard to their role or other tendency to produce a certain classification of document, additional metadata is required to establish the author.

Finally, in Chapter 5, we introduced the ASC model as a structure for bringing together the technologies of automated text categorisation to meet the requirements of a security classification. This involved a strict definition of what metadata should be extracted from a document and how this could be accomplished. We proceeded to provide several examples of how this generic model could be applied in a corporate environment, in the form of the Audit Tool, Safe Storage and Data Leakage Prevention applications.

As this research has shown, there are many possibilities for the application of automated text classification to the task of security classification. The limiting factors in technology can be significantly compensated with a proper implementation, such as was suggested by the application of hybrid classifiers or tuning parameters to create a ‘better safe than sorry’ classification decision. This model takes into account the significant elements provided by the input documents and provides a rich metadata, useful for subsequent security classification that is largely independent of the particular security policy used.

Copyright © 2008 Capgemini – All rights reserved

The contribution of this thesis is the introduction of the concept of automated security classification, as well as the proposal of a model and several technologies to realise this concept. We intended to show how the power of advanced text classification techniques can be harnessed to improve the speed and accuracy of identifying sensitive documents for security purposes. Many such automated classification technologies already exist and could be applied, as prescribed by the ASC model, in ways to facilitate specific and appropriate data protection in a "data-centric" environment.

6.3. Open Issues

The ASC model proposed a new use for some existing automated text classification technology. Although we have explained how these technologies can work together to address the initial problem of security classification, we are also left with some limiting factors and other issues that remain open.

Ultimately, security decisions require a higher level of accuracy and assurance than these classification technologies were originally required to provide. This introduces the possibility that these classifiers will never reach a level of accuracy that satisfies the prospective users of the ASC model. This was a point also made by many of the interviewees cited in this dissertation. A classifier that cannot absolutely guarantee zero false negatives might result in incorrectly assigning a public classification to a secret document. The consequences of even one such security breach could, in some cases, outweigh the savings in time and money, for which the system was originally designed. Although classification techniques are becoming more accurate, it is highly unlikely that they will ever be able to provide 100% assurance than no security breach will ever occur. If this is the case, the ASC will only provide a false sense of security that may, in turn, increase the chances of a security breach. It remains to be seen if better technology will make the ASC feasible in this context, or if a security classification scheme exists where the current level of assurance would be sufficient.

Furthermore, many assumptions were made regarding the set of documents that would be classified by the ASC model. This was done in an attempt to create a generic system largely independent of the particular document structure and content of any specific organisation. However, if this model were focussed on a particular document structure, such as the ODA international document architecture standard used by [92], it is possible that additional methods could be devised to extract richer metadata.

6.4. Future Work

The lack of experimentation is the limiting factor of this research. Such experimentation is necessary to judge the feasibility of the proposed ASC model. This would require finding a company with a strict, active classification policy. This company must then provide a sizeable amount of documents that have been pre-classified according to the security classification scheme. The proof of concept would be achieved if, with enough relevant example documents, a latent rule set can be found that accurately describes the different security classifications. This might reveal rules that were not even part of the official

Copyright © 2008 Capgemini – All rights reserved

classification policy. Positive results of such an experiment would be very useful to prove the feasibility of the ASC model and encourage further research and application, especially within the business community where such a system is required.

The ASC model creates a rich collection of metadata that could easily be put to other uses, such as ILM. Requirements for data classification for ILM are often less strict than for security. As described earlier, ILM currently uses the document age as the primary decision factor. By using a richer combination of metadata, as provided by the ASC model, the decision factors of ILM could be refined to include document types and topics. This could further allow ILM controls to be more specific to make more efficient use of tiered storage and archiving systems. Additionally, this collection of metadata might be put to use for data deduplication purposes that go beyond simple checksum and byte-level document comparison, but rather search for documents that cover the same topic with different words or derivatives of other documents.

Copyright © 2008 Capgemini – All rights reserved

REFERENCES

[1] T. Grandison et al., "Elevating the Discussion on Security Management: The Data Centric Paradigm," *2nd IEEE/IFIP International Workshop on Business-Driven IT Management*, 2007, pp. 84-93.

[2] "Data Loss Database," *Open Security Foundation*; http://datalossdb.org/.

[3] "A Chronology of Data Breaches," *Privacy Rights Clearinghouse*; http://www.privacyrights.org/ar/ChronDataBreaches.htm.

[4] W.L. Kuechler, "Business applications of unstructured text," *Communications of the ACM*, vol. 50, 2007, pp. 86-93.

[5] S. Godbole and S. Roy, "Text classification, business intelligence, and interactivity: automating C-Sat analysis for services industry," *Proceeding of the 14th ACM SIGKDD international conference on Knowledge discovery and data mining*, Las Vegas, Nevada, USA: ACM, 2008, pp. 911-919.

[6] A.S. Quist, *Security classification of information. Volume 1, History and Adverse Impacts*, United States Department of Energy, Oak Ridge Gaseous Diffusion Plant, 1989.

[7] R. Richardson, *CSI Survey 2007: The 12th Annual Computer Crime and Security Survey*, Computer Security Institute, 2007.

[8] R. Stanton, "Inside out security: de-perimeterisation," *Network Security*, vol. 2005, Apr. 2005, pp. 4-6.

[9] "Jericho Forum," *Open Group*; http://www.jerichoforum.org.

[10] D.C. Latham, *DoD Trusted Computer System Evaluation Criteria (5200.28 STD)*, U.S. Department of Defense, 1985; http://csrc.nist.gov/publications/history/dod85.pdf.

[11] T.B. Quillinan, *Secure Naming for Distributed Computing using the Condensed Graph Model*, University of Ireland, 2006.

[12] L. Lee, "" I'm sorry Dave, I'm afraid I can't do that": Linguistics, Statistics, and Natural Language Processing circa 2001," *Computer Science, National Research Council*, 2004, pp. 111-118.

[13] A.M. Turing, "Computing Machinery and Intelligence," *Mind*, vol. 59, Oct. 1950, pp. 433-460.

[14] "Bibliography on Automated Text Categorization"; http://liinwww.ira.uka.de/bibliography/Ai/automated.text.categorization.html.

[15] C.D. Manning and H. Schütze, *Foundations of Statistical Natural Language Processing*, MIT Press, 1999.

Copyright © 2008 Capgemini – All rights reserved

[16] D.D. Lewis and K.S. Jones, “Natural language processing for information retrieval,” *Communications of the ACM*, vol. 39, 1996, pp. 92-101.

[17] R. Basili, A. Moschitti, and M.T. Pazienza, “Language-sensitive text classification,” *Proceedings of RIAO’00, 6th International Conference “Recherche d’Information Assistee par Ordinateur*, 2000, pp. 331–343.

[18] R. Basili, A. Moschitti, and M.T. Pazienza, “NLP-driven IR: Evaluating performances over a text classification task,” *13th International Joint Conference on Artificial Intelligence IJCAI-01*, 2001, pp. 1286–1294.

[19] F. Sebastiani, “A Tutorial on Automated Text Categorisation,” *ASAI-99, 1st Argentinian Symposium on Artificial Intelligence*, 1999, pp. 7-35.

[20] F. Sebastiani, “Machine learning in automated text categorization,” *ACM Computing Surveys (CSUR)*, vol. 34, 2002, pp. 1-47.

[21] S. Deerwester et al., “Indexing by Latent Semantic Analysis,” *Journal of the American Society for Information Science*, vol. 41, 1990, pp. 391--407.

[22] M.E. Maron, “Automatic Indexing: An Experimental Inquiry,” *Journal of the ACM (JACM)*, vol. 8, 1961, pp. 404-417.

[23] C. Shannon and W. Weaver, “A mathematical theory of communications,” *Bell System Technical Journal*, vol. 27, 1948, pp. 632-656.

[24] N.J. Belkin and W.B. Croft, “Information filtering and information retrieval: two sides of the same coin?,” *Communications of the ACM*, vol. 35, 1992, pp. 29-38.

[25] H. Baayen et al., “An experiment in authorship attribution,” *Journées internationales d'Analyse statistique des Données Textuelles*, vol. 6, 2002, pp. 69-75.

[26] J. Diederich et al., “Authorship Attribution with Support Vector Machines,” *Applied Intelligence*, vol. 19, Jul. 2003, pp. 109-123.

[27] R. Richardson and A.F. Smeaton, “Automatic word sense disambiguation in a KBIR application,” *The New Review of Document and text management*, vol. 1, 1995, pp. 299-320.

[28] I. Androutsopoulos et al., “An evaluation of Naive Bayesian anti-spam filtering,” *Proceedings of the Workshop on Machine Learning in the New Information Age*, 2000.

[29] M. Malyutov, “Authorship attribution of texts: a review,” *Electronic Notes in Discrete Mathematics*, vol. 21, Aug. 2005, pp. 353-357.

[30] M. Lesk, “Automatic sense disambiguation using machine readable dictionaries: how to tell a pine cone from an ice cream cone,” *ACM Special Interest Group for Design of Communication: Proceedings of the 5 th annual international conference on Systems documentation*, vol. 1986, 1986, pp. 24-26.

Copyright © 2008 Capgemini – All rights reserved

[31] P.J. Hayes and S.P. Weinstein, "CONSTRUE/TIS: A System for Content-Based Indexing of a Database of News Stories," *Proceedings of the The Second Conference on Innovative Applications of Artificial Intelligence table of contents*, 1990, pp. 49-64.

[32] C.J. Fall and K. Benzineb, "Literature survey: Issues to be considered in the automatic classification of patents," *World Intellectual Property Organization, Oct*, vol. 29, 2002.

[33] "Google PageRank"; http://www.google.com/corporate/tech.html.

[34] X. He et al., "Automatic Topic Identification Using Webpage Clustering," *Proceedings of the 2001 IEEE International Conference on Data Mining*, Washington, DC, USA: IEEE Computer Society, 2001, pp. 195-202.

[35] H. Mase and H. Tsuji, "Experiments on Automatic Web Page Categorization for IR system," *Transactions of Information Processing Society of Japan*, vol. 42, 2001, pp. 334-348.

[36] G. Attardi, A. Gulli, and F. Sebastiani, "Automatic Web Page Categorization by Link and Context Analysis," *Proceedings of THAI*, vol. 99, 1999, pp. 105–119.

[37] E.F. Ogston, *Agent Based Matchmaking and Clustering*, Vrije Universitiet Amsterdam, 2005.

[38] P. Tom, *Data Protection and Information Lifecycle Management*, Prentice Hall PTR, 2005.

[39] D. Reiner et al., "Information lifecycle management: the EMC perspective," *Data Engineering, 2004. Proceedings. 20th International Conference on*, 2004, pp. 804-807.

[40] Y. Chen, "Information Valuation for Information Lifecycle Management," *Autonomic Computing, 2005. ICAC 2005. Proceedings. Second International Conference on*, 2005, pp. 135-146.

[41] *Summary of the HIPAA Privacy Rule*, United States Department of Health & Human Services, 2005; http://www.hhs.gov/ocr/privacysummary.pdf.

[42] *Directive 95/46/EC of the European Parliament and of the Council on the Protection of Individuals with Regard to the Processing of Personal Data and on the Free Movement of Such Data*, European Parliament, 1995; http://eur-lex.europa.eu/.

[43] *Directive 2002/58/EC of the European Parliament and of the Council concerning the processing of personal data and the protection of privacy in the electronic communications sector*, European Parliament, 2002; http://eur-lex.europa.eu/.

[44] *Payment Card Industry Data Security Standard*, PCI Security Standards Council, 2006; https://www.pcisecuritystandards.org/tech/pci_dss.htm.

[45] *Annual Study: U.S. Cost of a Data Breach*, Ponemon Institute, 2007; http://www.vontu.com/downloads/ponemon_07.asp.

Copyright © 2008 Capgemini – All rights reserved

[46] S.K. Nair et al., "A Virtual Machine Based Information Flow Control System for Policy Enforcement," *Electronic Notes in Theoretical Computer Science*, vol. 197, 2008, pp. 3-16.

[47] S. Haber et al., "If Piracy Is the Problem, Is DRM the Answer?," *LECTURE NOTES IN COMPUTER SCIENCE*, 2003, pp. 224-233.

[48] M. Matson and M. Ulieru, "Persistent information security: beyond the e-commerce threat model," *Proceedings of the 8th international conference on Electronic commerce*, 2006, pp. 271-277.

[49] J. McAdams, "Top Secret: Securing Data with Classification Schemes," *ComputerWorld*, Apr. 2006; http://www.computerworld.com/action/article.do?command=viewArticleBasic&articleId=110510&pageNumber=2.

[50] B. Berger, "Data-Centric Quantitative Computer Security Risk Assessment," *Information Security Reading Room, SANS*, 2003.

[51] P. Stamp, "Making Data-Centric Security Real," *Forrester Research*, vol. February 5, 2008.

[52] *DoD Information Security Program (5200.1 R)*, U.S. Department of Defense, 1996; http://www.dtic.mil/whs/directives/corres/html/520001.htm.

[53] *DoD National Industrial Security Program Operating Manual (5220.22 M)*, U.S. Department of Defense, 2006; http://www.dtic.mil/whs/directives/corres/html/522022m.htm.

[54] *DoD Handbook for Writing Security Classification Guidance (5200.1 H)*, U.S. Department of Defense, 1999; http://www.dtic.mil/whs/directives/corres/html/520001h.htm.

[55] *Executive Order 12958: Classified National Security Information*, U.S. Office of the President, 1995; http://www.dtic.mil/dpmo/general_info/eo12958.htm.

[56] A.S. Quist, *Security classification of information. Volume 2, Principles for classification of information*, United States Department of Energy, Oak Ridge Gaseous Diffusion Plant, 1993.

[57] *Standards for Security Categorization of Federal Information and Information Systems*, National Bureau of Standards and Technology (NIST), 2004; http://csrc.nist.gov/publications/fips/fips199/FIPS-PUB-199-final.pdf.

[58] *Guide for Mapping Types of Information and Information Systems to Security Categories, Volume I*, National Bureau of Standards and Technology (NIST), 2004; http://csrc.nist.gov/publications/nistpubs/800-60/SP800-60V1-final.pdf.

Copyright © 2008 Capgemini – All rights reserved

[59] *Guide for Mapping Types of Information and Information Systems to Security Categories, Volume II*, National Bureau of Standards and Technology (NIST), 2004; http://csrc.nist.gov/publications/nistpubs/800-60/SP800-60V2-final.pdf.

[60] *Data Classification Security Policy*, George Washington University, 2004; http://my.gwu.edu/files/policies/DataClassificationPolicy.pdf.

[61] *Data Access, Security, Classification and Handling*, Purdue University, 2007; http://www.purdue.edu/SSTA/security/newsletter/volume1/issue4/files/Data_HandlingSecurity_manual-ver2.pdf.

[62] "Stanford Data Classification Guidelines," *Stanford University, Secure Computing*, Oct. 2007; http://www.stanford.edu/group/security/securecomputing/dataclass_chart.html.

[63] *COBIT 4.1: Framework for Control Objectives Management Guidelines Maturity Models*, IT Governance Institute, 2007; http://www.isaca.org.

[64] *Information technology - Security techniques - Information security management systems - Requirements (ISO/IEC 27001)*, International Organization for Standardization, 2005; http://www.iso.org/.

[65] *Information technology - Security techniques - Code of practice for information security management (ISO/IEC 27002)*, International Organization for Standardization, 2005; http://www.iso.org/.

[66] *Information Sensitivity Policy*, SANS Institute, 2006; www.sans.org/resources/policies/Information_Sensitivity_Policy.pdf.

[67] G. Schmid, *Report on the existence of a global system for the interception of private and commercial communications (ECHELON interception system)*, European Parliament, 2001; http://www.europarl.europa.eu/.

[68] T. Aura, T.A. Kuhn, and M. Roe, "Scanning electronic documents for personally identifiable information," *Proceedings of the 5th ACM workshop on Privacy in electronic society*, Alexandria, Virginia, USA: ACM, 2006, pp. 41-50.

[69] *Identification Cards - Identification of issuers - Numbering system (ISO/IEC 7812)*, International Organization for Standardization, 2006; http://www.iso.org/.

[70] K. Aas and L. Eikvil, "Text categorisation: A survey," *Norwegian Computing Center*, vol. Report NR 941, 1999.

[71] C. Goller et al., "Automatic Document Classification: A thorough Evaluation of various Methods," *Informationskompetenz-Basiskompetenz in der Informationsgesellschaft. Proceedings*, vol. 7, 2000, pp. 145-162.

[72] M. Porter, *Porter Stemmer*; http://tartarus.org/~martin/PorterStemmer.

Copyright © 2008 Capgemini – All rights reserved

[73] Y. Yang and J.O. Pedersen, “A Comparative Study on Feature Selection in Text Categorization,” *Proceedings of the Fourteenth International Conference on Machine Learning table of contents*, 1997, pp. 412-420.

[74] T. Hofmann, “Probabilistic latent semantic indexing,” *Proceedings of the 22nd annual international ACM SIGIR conference on Research and development in information retrieval*, Berkeley, California, United States: ACM, 1999, pp. 50-57.

[75] D. Lewis, “Naive (Bayes) at forty: The independence assumption in information retrieval,” *Proceedings of the 10th European Conference on Machine Learning*, 1998, pp. 4-15.

[76] F. Peng, D. Schuurmans, and S. Wang, “Augmenting Naive Bayes Classifiers with Statistical Language Models,” *Information Retrieval*, vol. 7, 2004, pp. 317-345.

[77] K. Sang-Bum et al., “Some Effective Techniques for Naive Bayes Text Classification,” *IEEE Transactions on Knowledge and Data Enginering*, vol. 18, 2006, pp. 1457-1466.

[78] S. Dumais, “Using SVMs for text categorization,” *IEEE Intelligent Systems*, vol. 13, 1998, pp. 21–23.

[79] S. Dumais et al., “Inductive learning algorithms and representations for text categorization,” *Proceedings of the seventh international conference on Information and knowledge management*, Bethesda, Maryland, United States: ACM, 1998, pp. 148-155.

[80] A. Cardoso-Cachopo and A.L. Oliveira, “An Empirical Comparison of Text Categorization Methods,” *Proceedings of 10th International Symposium on String Processing and Information Retrieval*, vol. October 2003, 2003.

[81] J. Kivinen, M.K. Warmuth, and P. Auer, “The perceptron algorithm versus winnow: linear versus logarithmic mistake bounds when few input variables are relevant,” *Artificial Intelligence*, vol. 97, Dec. 1997, pp. 325-343.

[82] G. Sakkis et al., “Stacking classifiers for anti-spam filtering of e-mail,” *Proceedings of 6th Conference on Empirical Methods in Natural Language Processing*, vol. 1, 2001, pp. 44-50.

[83] L. Cai and T. Hofmann, “Text Categorization by Boosting Automatically Extracted Concepts,” *Proceedings of the 26th ACM International Conference on Research and Development in Information Retrieval*, 2003, pp. 182-189.

[84] “SpamAssassin,” *The Apache SpamAssassin Project*; http://spamassassin.apache.org.

[85] C. O’Brien and C. Vogel, “Comparing SpamAssassin with CBDF Email Filtering,” *Proceedings of the 7th Annual CLUK Research Colloquium*, 2004.

[86] W.S. Yerazunis, “The Spam-Filtering Accuracy Plateau at 99.9% Accuracy and How to Get Past it.,” *MIT Spam Conference*, Jan. 2004.

Copyright © 2008 Capgemini – All rights reserved

[87] S.T. Dumais, “Latent semantic indexing (LSI): TREC-3 report,” *The Third Text REtrieval Conference (TREC3)*, 1995, pp. 135-144.

[88] Y. Yang and X. Liu, “A re-examination of text categorization methods,” *Proceedings of the 22nd annual international ACM SIGIR conference on Research and development in information retrieval*, 1999, pp. 42-49.

[89] D.D. Lewis and M. Ringuette, “A comparison of two learning algorithms for text categorization,” *Proceedings of Third Annual Symposium on Document Analysis and Information Retrieval*, 1994, pp. 81-93.

[90] Y.H. Li and A.K. Jain, “Classification of Text Documents,” *The Computer Journal*, vol. 41, Aug. 1998, pp. 537-546.

[91] Y. Yang, “An Evaluation of Statistical Approaches to Text Categorization,” *Information Retrieval*, vol. 1, 1999, pp. 69-90.

[92] J.H.P. Eloff, R. Holbein, and S. Teufel, “Security classification for documents,” *Elsevier, Computers & Security*, vol. 15, 1996, pp. 55-71.

[93] “Safe Harbor”; http://www.export.gov/safeharbor/.

[94] E. Quellet and P.E. Proctor, “Magic Quadrant for Content Monitoring and Filtering and Data Loss Prevention,” *Gartner Group*, Jun. 2008.

[95] T. Raschke, “The Forrester Wave: Data Leak Prevention, Q2 2008,” *Forrester Research*, Jun. 2008.

Copyright © 2008 Capgemini – All rights reserved

Appendix A. INTERVIEWS

Braun, Therese and Nilsson, Daniel. *Cryptzone.* (Personal communication, 25 January 2008). Summary: During a conference call with Cryptzone, discussed their products which offer a total solution for encrypting emails, documents, folders and even total disks on servers, workstations and removable media. It can synchronise with rights management software to enforce user, group or role policies. Documents, emails and attachments can be encrypted either by choice, automated advice or automated enforcement. This involves integration with content-aware policy triggering products, such as Titus Labs or WorkShare.

Dupain, Peter. *Automated Enterprise Search, Autonomy*. (Personal communication, 20 February 2008). Summary: Discussed Autonomy Enterprise Search technology that indexes and clusters data together based on a combination of keyword and statistical analysis (Bayes classifier). Furthermore, if this technology could be used for identifying and clustering data based on sensitivity classifications. This classification engine is used by many other products on the market, such as Proofpoint, Semantic/Vontu and Websense.

Holtzer, Sanja. *Information Service, Stork BV – Capgemini BV.* (Personal communication, 6 March 2008). Summary: Discussed project on designing a similar system to automatically classify text-based information on sensitivity and importance for compliance. Basic steps were identified, including building a taxonomy of documents and training the algorithm with examples until accurate enough. Project eventually discontinued due to difficulty and expense of preparing system.

Koster, Cornelius. *Department of Informatics Professor, Radboud University Nijmegen*. (Personal communication, 7 April 2008). Summary: Discussed ASC model. Determined that experimentation is required before making any definitive conclusions about feasibility. Furthermore, after many years of research, most hope has been lost for the linguistic approach to text categorisation, as statistical classifiers have been growing ever more accurate and much easier to build and maintain.

Samwel, Paul. *Ir. CISSP Information Risk and Management, Rabobank Netherlands.* (Personal communication, 4 June 2008). Summary: Discussed current three-tier security classification at Rabobank that follows the traditional elements of confidentiality, integrity and availability. These labels are manually assigned to processes, applications and ICT products. Documents are currently not individually labelled.

Scholten, Hans. *Information Security Classification, Thales Netherlands*. (Personal communication, 13 February 2008). Summary: Discussed an information security classification and separation project carried out at Thales in order to make the company compliant to NATO standards. This included first separating the network

Copyright © 2008 Capgemini – All rights reserved

into three colour-coded regions of differing sensitivity, and then identifying and moving data to its appropriate network.

Seccombe, Adrian. *Chief Information Security Officer, Eli Lilly Pharmaceutical Company*. (Personal communication, 27 May 2008). Summary: Discussed current four-tier data security classification at Eli Lilly which attempts to combine elements of confidentiality, integrity and availability, as well as identity. Driven by compliance and reputation to protect sensitive customer data. New campaign to educate users to the need and meaning of each level of classification. Steps are people, process and then technology. Furthermore, proposed ASC model is not perceived as feasible as it tries to solve the entire problem solely with technology.

Ven, Jan van de. *Enterprise Architecture Consultant, Capgemini BV*. (Personal communication, 27 June 2008). Summary: Discussed ILM overview, requirements and data classification techniques. ILM offers the ability to automatically align documents to a multi-tiered storage based on document attributes, such as date created, last accessed and the role of an author. Policies are then manually created to specify which documents are stored at each tier, offering different response times and associated costs. These tools do not offer content scanning, as the complexity and high overhead presents no business case.

Wisse, Dirk. *Information Security Strategy, Royal Dutch Shell*. (Personal communication, 3 June 2008). *Summary:* Discussed Shell's current four-tier security classification policy, how and when documents were classified and possible room for improvement of this situation. Furthermore, we discussed the transition that is taking place to a security classification model that incorporates integrity and availability, in addition to the current confidentiality factor. Regarding the proposed ASC model, this would be unfeasible as it will be difficult to maintain and will not provide clear benefits. Subjective decisions are required too often that will be difficult to automate. However, this technology could be helpful for other purposes, such as human-assisted audit scans.

Copyright © 2008 Capgemini – All rights reserved

Appendix B. NIST SECURITY CATEGORISATIONS

This table summarizes the taxonomy of mission information, along with the security categorisation, as determined by NIST [59]. The full document provides additional information and rationale.

	Confidentiality	**Integrity**	**Availability**
Defense & National Security	Nat'l Security	Nat'l Security	Nat'l Security
Homeland Security			
Border Control and Transportation Security	Moderate	Moderate	Moderate
Key Asset and Critical Infrastructure Protection	High	High	High
Catastrophic Defense	High	High	High
Executive Functions of the EOP	High	Moderate	High
Intelligence Operations	High	High	High
Disaster Management			
Disaster Monitoring and Prediction	Low	High	High
Disaster Preparedness and Planning	Low	Low	Low
Disaster Repair and Restoration	Low	Low	Low
Emergency Response	Low	High	High
International Affairs and Commerce			
Foreign Relations	High	High	Moderate
International Development and Humanitarian Aid	Moderate	Low	Low
Global Trade	High	High	High
Natural Resources			
Water Resource Management	Low	Low	Low
Conservation, Marine, and Land Management	Low	Low	Low
Recreational Resource Management and Tourism	Low	Low	Low
Agricultural Innovation and Services	Low	Low	Low
Energy			
Energy Supply	Low	Low	Low
Energy Conservation and Preparedness	Low	Low	Low
Energy Resource Management	Moderate	Low	Low
Energy Production	Low	Low	Low
Environmental Management			
Environmental Monitoring/Forecasting	Low	Moderate	Low
Environmental Remediation	Moderate	Low	Low
Pollution Prevention And Control	Low	Low	Low
Economic Development			
Business and Industry Development	Low	Low	Low
Intellectual Property Protection	Low	Low	Low
Financial Sector Oversight	Moderate	Low	Low
Industry Sector Income Stabilization	Moderate	Low	Low
Community and Social Services			
Homeownership Promotion	Low	Low	Low
Community and Regional Development	Low	Low	Low
Social Services	Low	Low	Low

Copyright © 2008 Capgemini – All rights reserved

Postal Services	Low	Moderate	Moderate
Transportation			
Ground Transportation	Low	Low	Low
Water Transportation	Low	Low	Low
Air Transportation	Low	Low	Low
Space Operations	Low	High	High
Education			
Elementary, Secondary, & VocEd	Low	Low	Low
Higher Education	Low	Low	Low
Cultural & Historic Preservation	Low	Low	Low
Cultural & Historic Exhibition	Low	Low	Low
Public Health			
Illness Prevention	Low	Moderate	Low
Immunization Management	Low	Moderate	Low
Public Health Monitoring	Low	Moderate	Low
Health Care Services	Low	High	Low
Consumer Health and Safety	Low	Moderate	Low
Law Enforcement			
Criminal Apprehension	Low	Low	Moderate
Criminal Investigation and Surveillance	Moderate	Moderate	Moderate
Citizen Protection	Moderate	Moderate	Moderate
Leadership Protection	Moderate	Low	Low
Property Protection	Low	Low	Low
Substance Control	Moderate	Moderate	Moderate
Crime Prevention	Low	Low	Low
Trade Law Enforcement	Moderate	Moderate	Moderate
Litigation and Judicial Activities			
Judicial Hearings	Moderate	Low	Low
Legal Defense	Moderate	High	Low
Legal Investigation	Moderate	Moderate	Moderate
Legal Prosecution and Litigation	Low	Moderate	Low
Resolution Facilitation	Moderate	Low	Low
General Science and Innovation			
Scientific & Tech Research & Innovation	Low	Moderate	Low
Space Exploration & Innovation	Low	Moderate	Low
Knowledge Creation and Management			
Research and Development	Low	Moderate	Low
General Purpose Data and Statistics	Low	Low	Low
Advising and Consulting	Low	Low	Low
Knowledge Dissemination	Low	Low	Low
Public Goods Creation and Management			
Manufacturing	Low	Low	Low
Construction	Low	Low	Low
Public Facility and Infrastructure	Low	Low	Low
Information Infrastructure Management	Low	Low	Low

Copyright © 2008 Capgemini – All rights reserved

Appendix C. CLASSIFICATION FORMULAS

Boolean weighting	$a_{ik} = \begin{cases} 1 \; if \; f_{ik} > 0 \\ 0 \; otherwise \end{cases}$
Frequency weighting	$a_{ik} = f_{ik}$
Term frequency inverse document frequency (tfidf)	$a_{ik} = f_{ik} * \log\left(\frac{N}{n_i}\right)$
Term frequency collection (tfc)	$a_{ik} = \frac{f_{jk} * \log\left(\frac{N}{n_i}\right)}{\sqrt{\sum_{j=1}^{M}\left[f_{jk} * \log\left(\frac{N}{n_j}\right)\right]^2}}$
Length term collection (ltc)	$a_{ik} = \frac{\log(f_{jk} + 1.0) * \log\left(\frac{N}{n_i}\right)}{\sqrt{\sum_{j=1}^{M}\left[\log(f_{jk} + 1.0) * \log\left(\frac{N}{n_i}\right)\right]^2}}$
Entropy weighting	$a_{ik} = \log(f_{jk} + 1.0) * \left(1 + \frac{1}{\log(N)}\sum_{j=1}^{N}\left[\frac{f_{ij}}{n_i}\log\left(\frac{f_{ij}}{n_i}\right)\right]\right)$

Table C-1 Feature weighting formulas [70].

Document Frequency Thresholding (DF)	$DF(t)\begin{cases} retain \; if \; DF \geq T \\ remove \; otherwise \end{cases}$
Information Gain (IG)	$IG(t) = -\sum_{i=1}^{m}\Pr(c_i)\log Pr(c_i) + Pr(t)\sum_{i=1}^{m}Pr(c_i\|t)\log Pr(c_i\|t) + Pr(\bar{t})\sum_{i=1}^{m}Pr(c_i\|\bar{t})\log Pr(c_i\|\bar{t})$
Mutual Information (MI)	$MI(t,c) \approx \log\frac{A \times N}{(A+C)\times(A+B)}$
χ^2 statistic (CHI)	$\chi^2(t,c) = \frac{N \times (AD - CB)^2}{(A+C)\times(B+D)\times(A+B)\times(C+D)}$
Term Strength (TS)	$s(t) = Pr(t \in y \| t \in x)$

Table C-2 Dimensionality reduction methods [73].

Copyright © 2008 Capgemini – All rights reserved

Rocchio category vector [20]	$w_{ki} = \beta \cdot \sum_{d_j \epsilon POS_i} \frac{w_{kj}}{\lvert POS_i \rvert} - \gamma \cdot \sum_{d_j \epsilon NEG_i} \frac{w_{kj}}{\lvert NEG_i \rvert}$
Naïve (simple) Bayes [70]	$P(c_j \lvert d) = P(c_j) \prod_{i=1}^{M} P(d_i \lvert c_j)$
Naïve (simple) Bayes [19]	$P(c_i \lvert d_j) = \prod_{y=1}^{r} \left[P(c_i \lvert t_y) \cdot P(t_y \lvert d_j) + P(c_i \lvert \bar{t}_y) \cdot P(\bar{t}_y \lvert d_j) \right]$
k-Nearest Neighbours [19]	$CSV_i(d_j) = \sum_{\bar{d}_z \in TR_k(d_j)} RSV(d_j, \bar{d}_z) \cdot ca_{iz}$

Table C-3 Classifier methods.

Copyright © 2008 Capgemini – All rights reserved

Appendix D. OVERVIEW OF CURRENT PRODUCTS

This section will give an overview of products currently on the market that perform a task similar to the applications of the ASC model covered earlier. The information covered was obtained mostly from vendor provided white papers, product brochures, conference calls and webinars. One vendor was additionally personally interviewed involving a live product demonstration.

General Document Classification

The first group of products perform document classification for Information Retrieval (IR) or Information Lifecycle Management (ILM). In the context of this research, these products are useful to gauge the real-world application of some of the automated classification techniques discussed earlier.

Automony is one of the largest software vendors in Europe, according to Peter Dupain (see Appendix A) the second largest, after SAP. This company specialises in advanced search tools for enterprise IR that make use of advanced document classification techniques. Additional products are available for image and video classification, but these are outside the scope of this research.

According to Dupain, the classification engine makes primary use of a Bayes classifier and a keyword parser. This uses a user-provided taxonomy and at least 30 examples per category to produce category profiles that can be manually edited for better accuracy. This processing is performed on a centralised server with access to all relevant files on the network. A user interface then accepts search queries and returns clustered results revealing relationships to other categories and sub-categories. The classifier also makes use of Shannon's Information Theory when performing term selection, by observing that the more times a word is used in a document, the more relevant it is, but the more unique the word is across the entire set of documents, the more discriminating it becomes. This product provides a good combination of automated technology and manual guidance, and thus provides a possible lesson for the ASC model. In fact, according to Dupain, this classification technology is used by other products "under the hood" to perform their document classification for other purposes, such as DLP and ILM products from Symantec. This is a point reiterated by market analysts [94], who claim that Autonomy's content inspection technology is incorporated by "Palisade Systems, Proofpoint, Symantec/Vontu, Trend Micro and Websense" [94].

Inxight (recently acquired by SAP) provides an enterprise IR appliance that performs automatic document taxonomy generation, document classification and document summarisation for over 220 document formats and 30 major languages. The classification technology used is not specified beyond "sophisticated natural language processing" that includes POS tagging and synonym grouping.

Copyright © 2008 Capgemini – All rights reserved

Audit Tool Application

The following products are similar to the audit tool application of the ASC model proposed in earlier. They provide offline scanning of corporate networks to detect and report policy violations.

Abrevity provides an approach that combines document classification and management that can then be used to identify and report policy violations, apply security measures and even facilitate an ILM policy. Again, the classification technology used by this product is not specified beyond "keywords, phrases or patterns," which can be used to "identify and secure Non-Public Information (NPI), enforce data compliance (HIPAA, SOX, and so on) and facilitate a tiered-storage ILM policy.

Kazeon offers an information discovery platform that can identify policy violations and can take corrective action, such as notifying the user, blocking access to the file or moving the document to a secured location. A full network scan (audit) is performed nightly and any compliance violations are displayed via a central reporting platform. Again, the classification technology used by this product is not specified beyond "a set of rules to extract common, confidential patterns, such as phone numbers, social security numbers and credit card number" implying not advanced classification technologies beyond keyword parsing. The product offers reporting abilities giving the user an overview of file sensitivities and locations, as well as an extensive user notification system to raise security awareness.

Kazeon offers additional functionality outside the scope of this research, but still noteworthy. This includes advanced auditing reports, including file access information, data de-duplication, data retention management and tiered storage management.

Safe Storage Application

The following application is similar to the safe storage application of the ASC model proposed earlier. This product is capable of applying data confidentiality protections for individual documents, based on predefined security policies.

Cryptzone offers a total solution to data protection using strong encryption to protect the confidentiality at the document level and integration with rights management and content-aware triggering mechanisms to enforce security policies. This product offers both a Safe Storage application, as well as a Data Leakage Prevention application. In both cases, Cryptzone connects to external applications to provide the actual content scanning and classification. This is provided by DLP applications such as WorkShare that are described in the next section.

Documents are scanned at the point of creation or when they cross the perimeter either by network or removable media. If these documents violate security policies, they can either automatically be blocked or encrypted, or can simply notify the user of the possible risk and allow the user to follow or ignore the suggested action. Furthermore, the goal of this product is to be as transparent to the user as possible and therefore all settings can be made to achieve this, including single sign-on, automated decisions and policy enforcement.

Copyright © 2008 Capgemini – All rights reserved

Data Leakage Prevention Application

The following products are similar to the data leakage prevention application of the ASC model proposed earlier. These products are concerned with scanning the content of documents at the moment that they leave the protected environment to ensure they comply with security policy. This can include not only sensitive content, but also hidden metadata that reveals sensitive information, such as Tracked Changes in Word documents or simply the name of an author. Additional measures can be taken if the document violates security policies.

This is perhaps the most developed application of the ASC model, as can be seen by the large number of products on the market. Furthermore, there is much activity with larger software vendors buying smaller ones as a means to enter this developing market. This includes the acquisitions of Onigma by McAfee, Port Authority by Websense, Tablus by RSA Security, Oakley Networks by Raytheon, Provilla by Trend Micro and Vontu by Symantec. In order to become oriented with this market, several reports were consulted from both Gartner Group and Forrester Research to determine the market leaders and their defining attributes. These vendors offer very similar products and the comparisons focus on the slight differences, such as an additional component or lack thereof. However, these comparisons do not go into the detail of the classification technology used or its level of accuracy. Therefore, these products will be summarised on the basis of these reports and vendor supplied information.

The Forrester Wave [95] identified leaders in this market based on approximately 74 criteria, combining both the current offering and future strategy. This included protections for data-in-motion (network traffic), data-at-rest (discovery) and data-in-use (user workstation). Specifically, products were tested whether they are capable of protecting against internal, intentional attacks, or only against accidental security policy violations, that constitutes 80% of breaches, according to Forrester. The market leaders were identified as Websense, Reconnex, Verdasys, RSA Security and Vericept.

The Gartner Magic Quadrant [94] identified leaders in the market based on the completeness of their product solution and their market strategy. To be included in the comparison required the use of sophisticated, content-aware detection techniques, the ability to block policy violations, the ability to analyse multiple channels, such as HTTP, USB, FTP, and so on, and sufficient market presence. The market leaders were identified as Reconnex, RSA Security, Vontu (Symantec), Vericept and Websense.

Websense Data Security Suite offers a total solution to data leakage protection. This includes network and desktop agents that can filter email content and attachments, block suspicious HTTP file uploading and even print commands. This product uses a combination of keyword filtering, regular expression filtering and document fingerprinting to identify and monitor sensitive documents. After fingerprinting a document, it will be monitored and protected against policy violations, even if the document is slightly modified.

Reconnex combines a centralised appliance with a desktop agent. Policies can be defined centrally, that can then be enforced by the agent, such as preventing documents from

Copyright © 2008 Capgemini – All rights reserved

being copied or moved. If policy violations are detected, the user can either be notified or the action can be enforced, such as encryption or prevention. Furthermore, this product can assist in creating a document taxonomy using data mining techniques and historical trending. This product first scans the network to identify sensitive information, in the same fashion as the audit tool application described in the last section. Once these files have been identified and marked, they can be filtered and blocked if they attempt to leave the secured environment.

Verdasys offers the Digital Guardian that has the strongest data-in-use protections, according to the Forrester comparison. This includes discovering, classifying, monitoring and controlling data on workstations and handheld endpoints, both online or offline, and applying policies that warn, alert or block improper data usage and automatically apply countermeasures, including file and email encryption. In addition to other, unspecified classification techniques, this product uses Bayesian analysis to identify file types. This product has the strongest endpoint function according to the Gartner comparison, but no network component.

RSA Security offers a DLP suite that includes the strongest discovery features in the market, according to the Forrester comparison, using advanced content identification techniques it has incorporated through its acquisition of Tablus. Furthermore, this product supports a large number of distributed discovery agents, ideal for larger enterprises. As with most products mentioned, this offers scanning modules for discovery, network filtering and endpoint monitoring.

Vericept has a broad suite of classification methods, such as linguistic analysis, behavioural indications and concept identification. This enables the product to detect when content has been paraphrased, but still has the same meaning. This classification mechanism uses the Content Analysis Description Language (CANDL) that allows manual modification of classification rules. When a policy violation is detected, the software can automatically take action, such as blocking, encrypting or quarantining the file. Additionally, an automated system can educate users on specific policy abuses. The classification technologies include exact content matching, full and partial data matching, keyword and regular expressions, contextual and linguistic analysis and concept analysis that increases accuracy by using multiple scans and user feedback during the training phase.

Vontu is well integrated into Symantec's growing suite of computer security products. This includes modules for endpoint monitoring, network filtering and file server scanning. Additionally, this product suite includes powerful workflow mechanisms to control document usage and routing, allowing for automated response to policy violations. According to the Gartner comparison, these are the strongest network and workflow capabilities in the market. The classification engine incorporates Autonomy's content analysis technology discussed in the last section.

Copyright © 2008 Capgemini – All rights reserved

Capgemini

CONSULTING.TECHNOLOGY.OUTSOURCING

Capgemini Netherlands B.V.
(F55) Architecture Governance and Secured Infrastructure
Papendorpseweg 100
3500GN Utrecht
+31 (0) 30 6890000
www.nl.capgemini.com